

Answer Part 1

Repository and collaboration

Phanuwit Butchari - 67070501070

Peer: Pitchai Chadchuangchot - 67070501068 (Datakung)

REVIEW DRAFT - not ready for submission. PRs #31-35 are peer-approved and merged into staging. Issue #30 is in progress. The release review, main merge, final-main command outputs, completed Project, human visual checks and student review of the Reflection remain pending.

[Repository](#) · [Project](#) · [Release Issue #30](#)

This copy was generated 2026-09-26T10:07:11.983Z from checkout HEAD aab88a11a144ad966127c9dd1ffe505935b4ac5d. Local release documentation may be uncommitted during preparation. Links to lab3-staging follow the live review branch; capture provenance is pinned separately. This is not a final-main record.

Feature branches → lab3-staging → main

The first five work items are complete. The sixth release PR supplies the peer-reviewed staging-to-main integration. This graph is a current staging snapshot; final main and completed Project evidence are pending.

```
* aab88a1 (HEAD -> lab3-staging) docs(lab3): refine report tables and directory links
* 747e0a6 docs(lab3): prepare release checklist and reproducible review report
* 775e727 docs(lab3): close issue 29 after independent approval and merge
* e685eec (origin/lab3-staging) Merge pull request #35 from auto4496/codex/lab3-5-system-verification
|\
| * 3d251ce (origin/codex/lab3-5-system-verification) docs(lab3): record integrated verification and curated visual
| evidence
| * 5a0934e test(lab3): complete dialog API stub for modal cleanup
| * 08d3711 test(lab3): verify integrated workflows and preserve modal keyboard focus
|/
* 2c6f799 Merge pull request #34 from auto4496/codex/lab3-4-user-administration
|\
| * c84ad03 (origin/codex/lab3-4-user-administration, codex/lab3-4-user-administration) fix(lab3): guard dirty account
| navigation and scope success assertions
| * 88922cb docs(lab3): record administrator review handoff
| * 25776f3 feat(lab3): add administrator user management with account safety
|/
* f13469c Merge pull request #33 from auto4496/codex/lab3-3-staff-workflow
|\
| * 37d5cd5 (origin/codex/lab3-3-staff-workflow, codex/lab3-3-staff-workflow) fix(lab3): reconcile latest conversation
| page after uncertain posts
| * 4196fc9 docs(lab3): record verified staff workflow review handoff
| * f8c1f49 feat(lab3): implement staff ticket workflow and conversations
|/
* 1bf4588 Merge pull request #32 from auto4496/codex/lab3-2-auth-requester
|\
| * 82d7019 (origin/codex/lab3-2-auth-requester, codex/lab3-2-auth-requester) fix(auth): recover rejected CSRF and restore
| permitted destinations
| * 7f2a5dd docs(lab3): confirm foundation issue development link
| * bb296b6 docs(lab3): record foundation PR and review handoff
| * 3c42711 feat(lab3): add authentication and requester foundation (#26)
|/
* ec5dece Merge pull request #31 from auto4496/codex/lab3-1-engineering-contract
|\
| * 609b2ed (origin/codex/lab3-1-engineering-contract, codex/lab3-1-engineering-contract) docs(lab3): address contract
| workflow review
| * 923648d docs(lab3): record contract PR and validation handoff
```

```
| * b006797 docs(lab3): define engineering contract and six-issue plan  
|/
```

Rendered source: <docs/lab-03/reviewer.md> - complete document; dated historical entries retained.

Lab 3 Peer Review Record

Status (2026-09-26): PRs #31-35 are approved and merged into staging. Work items #25-29 are complete. Issue #30 is Started; the staging-to-main release and review PDF are being prepared. Final-main verification and submission are not yet complete. See [release checklist](#). Earlier pending statements below are historical.

System verification integration - 2026-09-26

Datakung approved PR #35 commit 3d251ce2ecd074bb18792f0b7aae85a0589645a at 2026-09-25 18:07:08 UTC (2026-09-26 01:07:08 Bangkok). The reviewer independently passed all 389 tests, all 17 browser journeys and both production builds, verified all 109 screenshot checksums, and reported no blocking findings. The peer merged at 18:07:29 UTC as e685eec892d2b09fdeeeafcb8dc0c253ae6c4f31.

[Actual review and merge](#). No correction or additional approval is needed for #29. Final-main verification, final PDF, native browser zoom/final human inspection and the student's reading of the Reflection remain #30. This post-merge documentation closeout is included in the staging-to-main release review; it does not alter the approved application.

Administrator integration - verified 2026-09-25

Datakung approved correction c84ad03e191a9ce8f81d2829dd50c0de4b9b6cf3 on 2026-09-22 at 14:30:11 UTC. Their re-review passed 85 client cases, the original independent reproduction, all 13 browser tests and both builds. The peer did not rerun the full API/unit suite for that frontend correction. PR #34 merged at 14:30:21 UTC as 2c6f79938ec17573e8727639c34e60eefbc190c5.

The user authorized replies confirming both fixes; actual replies are [navigation correction](#) and [specific success assertion](#). Issue #28 was closed and moved to Done after the verified merge. This supersedes the earlier pending/reply-not-sent notes.

System verification handoff - Issue #29 (historical, before approval)

Branch `codex/lab3-5-system-verification` starts at the PR #34 merge above. Scope: integrated regression, failure rollback, responsive/state captures, evidence mapping, README and the nine-part submission draft. [System verification](#) records actual checks and limitations. Review capture provenance, real versus simulated evidence, retained migration/data checks and accessibility assertions. Only the approving peer may merge; no independent approval or final-main run is claimed.

Handoff: [PR #35](#), target `lab3-staging`. Source/capture commit 08d3711, completed jsdom fixture 5a0934e, evidence/results commit 3d251ce. Final author checks: 389 Vitest cases in 36 files, 17 browser journeys, both builds, 109 verified image checksums and local document links passed. Issue #29's formal Development link is verified through closingIssuesReferences. After linking, the board read Specified; it was corrected and read back as PR Review. Issue #30 remains Backlog. No separate reviewer message/request was sent, and no peer approval or merge is claimed.

Administrator handoff - 2026-09-20

Peer correction - 2026-09-21

Datakung requested changes on reviewed head 88922cb: [dirty in-app navigation](#) and [ambiguous success notices in browser assertions](#). The reviewer independently passed all 378 tests and both builds; their full browser run had 11 passes and one timing-sensitive failure, followed by a passing targeted rerun. That targeted rerun is not recorded as a clean full-suite pass.

The correction connects the editor's dirty state to the App router, confirms shell navigation and native Back/Forward before unmounting, preserves the draft on Cancel, and bypasses the guard for logout/mandatory authentication changes. Both success assertions now filter by their intended notice text, without sleeps or arbitrary first matches. Five new App-level tests

failed before the fix and pass afterward; a real browser Back/Forward journey was added. Current correction verification is recorded in tests.md. Peer re-approval remains pending; no review reply or re-review request has been sent on the user's behalf for this correction.

- Issue [#28](#), [PR #34](#), target lab3-staging.
- Implementation/evidence commit: 25776f3. The follow-up handoff commit changes documentation only; review the live PR head.
- Formal Development relationship is verified by the PR closingIssuesReferences API. Project status: PR Review.
- Author verification: 378 Vitest cases in 34 files, 12 browser journeys, both builds and diff check passed. Actual results, initial failures and screenshot inspection are in tests.md; implementation decisions are in user-management.md.
- Requested reviewer attention: shared account/ticket lock ordering, real concurrent last-admin and owner eligibility protection, reset/session revocation, and explicit conflict review without losing draft values.
- No independent review is claimed. No review request or message was sent on the user's behalf for this new PR. Await peer feedback and approval; do not self-merge.

Baseline: completed Lab 2 main f124c72. Flow: feature branches -> lab3-staging -> main. The existing local Lab 2 report edits are outside this worktree and this PR.

Participants

Author account: auto4496 (Phanuwit Butchari, student ID 67070501070). Lab 3 peer reviewer: Datakung (Pitchai Chadchuangchot, 67070501068), verified by the actual review submitted on 2026-09-12.

Engineering contract review handoff

- Scope: specification.md, api-spec.md, ui-spec.md, tests.md, issue-plan.md, reviewer.md, ai-use.md.
- Branch: codex/lab3-1-engineering-contract; target lab3-staging.
- GitHub Issue: [#25](#). Pull Request: [#31](#), OPEN against lab3-staging.
- Formal Development link: created through GitHub addCloseIssueReferences and verified in PR closingIssuesReferences. At review time the live board had #25 Specified and #26 Started, contrary to the earlier record. Correction workflow: #25 moves to Fixing while corrections are prepared, then PR Review after the correction is pushed and answered; #26 returns to Backlog. #27-#30 remain Backlog.
- Initial contract commit: b006797c3fb185a36f84992bb99cfd453bc90e60; subsequent documentation-only handoff commit records the actual PR link. Review the current PR head, not an assumed unchanged SHA.
- Reviewed commit: 923648db0817724e115db4ff456ebb728bfb3e43. Reviewer: Datakung. Outcome: Changes requested at 2026-09-12 06:32:12 UTC (13:32:12 Asia/Bangkok).
- Author checks on 2026-09-08: 18 unique FRs, 30 unique BRs, 24 unique ACs; all 24 ACs reference planned tests; seven documents and their internal file links validated. Staged git diff --check passed. Cross-check against existing code corrected the inherited attachment-removal body to reason, retained the bare attachment-metadata response and preserved Requester sort metadata. No runtime feature claims.
- Key decisions: narrow Admin ticket access, assignment eligibility, transition matrix, terminal conversations vs inherited attachments, password/session/CSRF policy, initial-password migration and concurrency safety.
- UI direction: user specifically requested attractive UI consistent with the assignment; check queue density, responsive cards, hierarchy, and private/public separation against ui-spec.md.

Review checklist

- [] Contract predates implementation; FR/BR/AC IDs and planned tests cover the complete handout scope.
- [] API routes/shapes/statuses and role/state rules agree with specification and UI.
- [] Migration preserves existing identity/attachments/idempotency and handles initialization safely.
- [] Authentication/CSRF/role/ownership/concurrency rules are explicit and testable.
- [] Zen Green components and desktop/tablet/mobile states meet the requested quality.
- [] Excluded screenshot features were not accidentally added.

- [] PR diff contains only the linked Issue work; GitHub Development link is present.
- [] Real findings have correction commits and individual responses; approvals/merges recorded only after they occur.

Findings and responses

PR #33 conversation recovery correction - 2026-09-16

Datakung requested changes on 4196fc9 after independently passing all 344 tests, ten browser journeys and both builds. [The inline finding](#) reproduces a saved 21st entry whose response is lost: reloading page 1 hid that entry on page 2 while enabling retry.

Correction: retain an uncertain-post recovery marker per ticket/conversation resource. Read pagination metadata, follow the current last page and display its entries before enabling a deliberate retry. Failed reads and tab switches do not clear the marker. Retain the relevant draft and never automatically replay POST. Three new regression cases cover public comments, internal notes, delayed last-page loading and failed recovery followed by a tab switch. All three failed on the reviewed implementation and pass after the correction. Client-suite/build verification is recorded in tests.md. This correction does not claim peer approval.

Issue #27 author verification - 2026-09-16

The user requested “ทำ 3 ต่อเลย” and then “ทำต่อเลย”. Implementation is isolated on `codex/lab3-3-staff-workflow`, based on PR #32 merge 1bf45888cdf4691f198d2c3d9ca38b164b6516f0 (merged 2026-09-15 at 07:32:17 UTC). PR #32's two findings were corrected in 82d7019 before peer approval/merge. The live Project item for #27 was moved to Started.

Review this increment's queue query semantics, private-note exclusion, strict role matrix, operational version checks, terminal exceptions and shared account-lock ordering. Real concurrent API tests and complete status-edge coverage are in `staff-workflow.api.test.ts`; browser journeys include Admin's restricted ticket view and Requester indication. No new database migration or development-data reset is included. The upcoming user-administration increment must use the documented shared lock and add actual Admin endpoint races.

Author verification results and selected screenshot paths are recorded in tests.md and staff-workflow.md. These are author checks, not an independent peer review. No approval, resolved peer finding or reviewer merge of this increment is claimed in advance.

Handoff: [PR #33](#), implementation/evidence commit f8c1f4971211ad2f385cfd956990d021515d4a0e, targets lab3-staging. Issue #27 was formally linked through Development and moved to PR Review; both were verified through GitHub's API on 2026-09-16. Full author verification: 344 Vitest cases, ten browser journeys and both builds passed. Independent peer review/approval/merge remain pending.

2026-09-12: Project status and evidence mismatch

- [Review finding](#): the formal Issue link exists, but #25 was Specified and #26 Started. Return #25 to PR Review and #26 to Backlog until the contract is approved and merged; align the records with the live board.
- Correction: return #26 to Backlog, use Fixing for #25 during correction and PR Review for re-review, and correct the outdated no-review claims and board history in the documentation.
- Existing #26 authentication helpers and tests remain uncommitted local drafts in the separate lab3-foundation worktree. They are not included in this contract PR or treated as a completed/approved implementation increment. Further #26 work waits for contract approval and merge.
- Reviewer verification: documentation-only scope; git diff --check, internal Markdown links and FR/AC traceability checked. No runtime tests expected for this PR.
- Author correction verification: review the documentation diff, internal links and ID/test coverage; verify actual Project statuses after updating the board. The correction commit and reply are visible in this PR's history and linked review thread.
- Follow-up approval and merge: pending the peer's actual decision. Resolving an addressed comment does not dismiss the Changes requested review or constitute approval.

Contract integration and foundation handoff

The historical pending note above was superseded by Datakung's actual approval and merge of PR #31 on 2026-09-13 at 04:47:19 UTC. Merge commit: `ec5deceea1e00fa2ddb60572fa741f284eb89796`. Issue #25 is closed. Issue #26 implementation was explicitly authorized by “เริ่มทำต่อเลย” and started from that staging commit in its separate foundation worktree.

Foundation review should inspect session/CSRF enforcement, the non-verifiable password sentinel refinement documented in foundation.md, preservation of legacy relations, safe repeat seed, real Requester regression coverage and screenshots. Staff/Admin operational features remain outside this PR. No independent review, approval or merge of #26 is claimed until the peer actually performs it.

Handoff: [PR #32](#), implementation commit `3c427117f18d705f79107e9c0e92a9f4cbd90ca1`, targets `lab3-staging`. Issue #26 is in PR Review and formally linked in Development, verified in the GitHub sidebar and closingIssuesReferences after the user signed in. Peer review and merge remain pending.

PR #32 requested changes - 2026-09-15

Datakung reviewed `7f2a5dd` and requested changes for [stale CSRF recovery](#) and [intended-route restoration](#). The peer independently passed 51 client tests and both builds, reproduced the CSRF defect with an additional test, and explicitly did not rerun database/E2E checks.

Corrections: discard the rejected cached CSRF token so only a subsequent deliberate mutation attempt bootstraps a fresh token; do not retry the failed mutation automatically. Preserve an allowlisted internal destination through login and the initial-password gate (including reload), then validate against the authenticated role before returning there. Invalid/external/disallowed destinations use the role landing page. Successful logout clears the pending destination.

`ReviewRegressions.test.tsx` added nine cases. Before corrections, four cases failed (login/logout CSRF refresh and both destination-restoration cases); five rejected-destination cases passed. After correction, all 60 client tests across nine files passed, with both production builds passing. No database/E2E rerun is claimed for this frontend correction.

The live board was independently found at Specified despite the earlier handoff record. It was moved to Fixing during correction; the handoff returns it to PR Review and verifies the persisted value. Corrections do not dismiss the peer's Changes requested review; follow-up approval/merge remain pending.

Setup and repository structure

Rendered source: [README.md](#) - complete document; dated historical entries retained.

TokTickIT - Lab 3 Service Desk

TokTickIT is an IT service-desk application with session authentication, Requester tickets and attachments, an IT Staff queue and workflow, and Administrator account management. See [foundation setup and migration](#) before upgrading an existing Lab 2 database, [staff workflow](#), and [user management](#). Integrated verification in [Issue #29](#) is peer-approved and merged. The [release checklist and review-report command](#) track [Issue #30](#), including the remaining final-main checks and submission PDF.

Role	Main screens	Responsibilities
Requester	<code>/tickets</code> , <code>/tickets/new</code> , <code>/tickets/:id</code>	Own tickets, attachments, public comments and resolution indication
IT Staff	<code>/staff/tickets</code> , <code>/staff/tickets/:id</code>	Search/filter queue, claim/assign, priority/status, public comments and private notes
Administrator	<code>/admin/users</code> , <code>/staff/tickets</code>	Create/edit/reset accounts; read ticket conversations and change IT Priority

Initial-password accounts must change their password before using the application. There is no self-registration, email reset or account deletion. Authorization is enforced by the API as well as the interface.

Technology Stack

- Frontend: React, TypeScript, Vite, Bootstrap
- Backend: Node.js, Express, TypeScript
- Database: PostgreSQL and Prisma
- Testing: Vitest, Supertest, React Testing Library, and Playwright

Repository Structure

```
toktickit/
├── client/
│   ├── src/
│   ├── package.json
│   └── vite.config.ts
├── server/
│   ├── prisma/
│   │   ├── migrations/
│   │   ├── schema.prisma
│   │   └── seed.ts
│   ├── src/
│   ├── tests/
│   │   ├── lab-01/
│   │   ├── lab-02/
│   │   └── lab-03/
│   └── package.json
├── e2e/
│   ├── lab-02/
│   └── lab-03/
├── artifacts/
│   ├── lab-02/screenshots/
│   └── lab-03/screenshots/
├── docs/
│   ├── lab-01/
│   ├── lab-02/
│   └── lab-03/
├── .env.example
├── .gitignore
├── package.json
├── playwright.config.ts
└── vitest.config.ts
```

Prerequisites

- Node.js and npm
- PostgreSQL 17, either installed locally or running in Docker
- Git

Installation

From the repository root, install the dependencies:

```
npm ci
npm --prefix client ci
npm --prefix server ci
```

Create the local environment file. Do not commit this file.

PowerShell:

```
Copy-Item .env.example .env
```

macOS/Linux:

```
cp .env.example .env
```

The default template expects PostgreSQL at localhost:5432, database toktickit_db, username postgres, and password postgres. Adjust the local .env if your database configuration is different.

Optional PostgreSQL Docker Container

If port 5432 is free, start a local PostgreSQL container with:

```
docker run --name toktickit-postgres -e POSTGRES_USER=postgres -e POSTGRES_PASSWORD=postgres -e POSTGRES_DB=toktickit_db -p 5432:5432 -d postgres:17-alpine
```

For an existing stopped container, use:

```
docker start toktickit-postgres
```

Database Setup

The Prisma scripts run from server/ and explicitly load the repository-root .env.

```
cd server
npm run prisma:generate
npm run prisma:deploy
npm run prisma:seed
cd ..
```

For existing Lab 2 data, complete the private account initialization in [the migration guide](#) before restarting the application. Seed is idempotent and preserves existing edits/passwords. It includes accounts, sample Tickets/conversations and these category names:

1. Account and Access 2. Hardware 3. Software 4. Network

Run the Application

Open two terminals at the repository root.

Backend:

```
npm run dev:server
```

Frontend:

```
npm run dev:client
```

Default URLs:

- Frontend: <http://localhost:3000>
- Health endpoint: <http://localhost:5000/api/health>
- Category endpoint: <http://localhost:5000/api/categories>
- Create Ticket screen: <http://localhost:3000/tickets/new>
- Create Ticket endpoint: POST <http://localhost:5000/api/tickets>
- My Tickets screen: <http://localhost:3000/tickets>
- My Tickets endpoint: GET <http://localhost:5000/api/tickets>
- Ticket Detail endpoint: GET <http://localhost:5000/api/tickets/:ticketId>
- Attachment upload endpoint: POST <http://localhost:5000/api/tickets/:ticketId/attachments>

- Attachment metadata/download/removal endpoints: `/api/attachments/:attachmentId`

The health endpoint returns:

```
{
  "status": "ok",
  "service": "TokTickIT API"
}
```

The category endpoint returns the seeded categories in ID order:

```
[
  { "id": 1, "name": "Account and Access" },
  { "id": 2, "name": "Hardware" },
  { "id": 3, "name": "Software" },
  { "id": 4, "name": "Network" }
]
```

Open `/login`, sign in with an active account and replace its initial password if prompted. Requesters can then use **Create Ticket** and **My Tickets**. Creation validates fields/files, prevents duplicate submissions with an idempotency key, and uploads attachments after saving the Ticket. My Tickets exposes only the signed-in Requester's records with filters, sorting, pagination, desktop tables and mobile cards. Ticket Detail preserves owned Attachment upload/download/soft-removal. Reference and Ticket endpoints now require a session; the health endpoint remains public.

Tests and Builds

Automated tests require a separate PostgreSQL database or schema. Copy the test template, edit it if necessary, and migrate that test-only target as documented in [Q](#):

```
Copy-Item .env.test.example .env.test.local
```

Edit `.env.test.local` SO `TEST_DATABASE_URL` points to a dedicated PostgreSQL database or schema whose name contains a distinct test marker. It must not match the development `DATABASE_URL`. Install the browser used by the reproducible E2E suite once:

```
npx playwright install chromium
```

Run all currently implemented automated tests. Vitest fails fast unless `TEST_DATABASE_URL` clearly identifies a test-only target distinct from `DATABASE_URL`:

```
npm test
npm run test:e2e:lab3
```

`npm run test:e2e` writes generated screenshots only under the ignored `test-results/` directory. Refresh the curated Lab 2 evidence explicitly when needed:

```
npm run test:e2e:capture
```

The Playwright setup validates the same test-only URL guard before it deploys migrations, seeds reference data idempotently, or clears only E2E-owned Ticket rows and their related Attachment and creation-request rows. It never uses the development database. The E2E suite runs the API and client on isolated ports 5100 and 3100, checks desktop 1440x900, tablet 834x1112, and mobile 390x844. Only `npm run test:e2e:capture` refreshes the curated screenshot evidence under `artifacts/lab-02/screenshots/`.

Build both applications:

```
npm run build:server
npm run build:client
```

test:e2e:lab3 includes the retained Lab 2 journeys plus authentication, Staff and Administrator workflows and cross-role system verification. test:e2e remains the Lab 2 subset. Override E2E_CLIENT_PORT and E2E_API_PORT if the defaults are already in use. Never run two suites against the same test database concurrently.

```
npm run test:e2e:capture:lab3
```

This explicit command runs the complete browser suite, then copies its Lab 3 screenshots to artifacts/lab-03/screenshots/system/ only after success. A manifest records the capture time, Git baseline/working-tree state and PNG checksums. Routine runs write only to ignored test-results/. Synthetic failure/empty-state captures are labelled in filenames; they do not prove server behavior. Real HTTP/database tests provide that evidence separately.

See [system verification](#), [test traceability](#), [review history](#), [AI use and reflection draft](#), and the [nine-part submission draft](#). Historical run results are dated and are not final-main acceptance.

Ignored generated and private files

```
# Dependencies
node_modules/
.pnpm-store/

# Environment Variables
.env
.env.local
.env.development.local
.env.test.local
.env.production.local
*.initial-passwords.json

# Build Outputs
dist/
build/
out/
.vite/

# Logs
logs
*.log

npm-debug.log*
yarn-debug.log*
yarn-error.log*
pnpm-debug.log*

# Testing & Coverage
coverage/
.vitest/
tmp/
server/tmp/
output/
playwright-report/
test-results/
blob-report/

# OS / Editor Files
.DS_Store
Thumbs.db
.vscode/
.idea/
```

Answer Part 2

Specification and acceptance contract

The contract originated in [PR #31](#) before implementation PRs #32-35. [Original contract commit](#). The rendered living document retains dated amendments and original planning language. Final Definition of Done sign-off remains pending.

Rendered source: [docs/lab-03/specification.md](#) - complete document; dated historical entries retained.

Lab 3 Sprint Engineering Specification

Status (2026-09-26): Contract approved in PR #31; implementation and integrated verification are peer-approved and merged through PR #35. Issue #30 is preparing the staging-to-main release. Final-main acceptance and the final Definition of Done sign-off remain pending. Dated historical plans are retained; current execution evidence is in [system-verification.md](#) and remaining work in [release.md](#).

Source: CPE 334 Lab 3 handout, "TokTickIT Users, Roles, IT Staff Ticketing, and Admin Screens", 18 pages. This contract interprets the handout; explicit exclusions take precedence over extra controls in its illustrative screenshots.

Baseline: completed Lab 2 main at f124c72. Lab 3 work is isolated from unfinished local Lab 2 report edits.

1. Sprint Goal

Replace temporary requester selection with authenticated accounts and backend authorization, preserve existing Requester tickets and attachments, deliver the first operational IT Staff queue and ticket workflow, and provide small, usable Administrator account-management screens in the existing Zen Green design language.

2. Stakeholder Request

Requesters sign in and continue managing their own reports. IT Staff find, accept, prioritize, discuss, and progress tickets. Administrators maintain one-role user accounts and initial passwords. Initial-password users must choose a new password before accessing application data. Public conversation and private operational notes remain clearly separated in both UI and API.

3. Scope

Included: login/logout/current user/password change; role-specific navigation; server-side identity, role and ownership checks; data migration and local seed; Requester regression and resolution indication; staff queue/detail/assignment/priority/status; append-only comments and notes; minimal user administration; traceable tests, responsive/visual review and course evidence.

Excluded: registration, invitations, password-reset email, MFA, social login/SSO, Actions Taken/Service Actions, SLA/escalation/notifications, analytics beyond queue counts, production hosting changes, multiple roles per user, user deletion/bulk/import/export, departments/profile photos/account history, unlock/approval workflows. Admin list pagination, multi-column sorting and multiple simultaneous filters are not required. No new inline attachment preview.

4. Functional Requirements

ID	Requirement
FR-01	Authenticate active users by email/password and return only safe current-user data.
FR-02	Gate initial-password sessions until successful password change; support logout and session expiration.

ID	Requirement
FR-03	Display current name/role and only permitted navigation; clear protected client data on identity change or session loss.
FR-04	Enforce role and requester ownership at every protected backend operation, including direct attachment requests.
FR-05	Migrate RequesterUser into User without losing IDs, tickets, attachment history/bytes or creation-idempotency relationships.
FR-06	Continue Lab 2 create/list/detail and attachment validation/download/soft-removal behavior through authenticated Requester identity.
FR-07	Provide staff queue search, filters, deterministic sorting, pagination and assigned/unassigned information.
FR-08	Provide role-authorized staff detail and safe attachment metadata/download continuity.
FR-09	Permit IT Staff to claim, assign/reassign and clear a ticket owner, subject to active eligible-user checks and conflicts.
FR-10	Initialize IT Priority from Requested Priority; permit operational updates without changing the requested value.
FR-11	Enforce the documented eight-status transition matrix, owner preconditions and confirmations.
FR-12	Let an owning Requester append public comments and indicate apparent resolution without formally resolving/closing.
FR-13	Let IT Staff append public comments/internal notes; return notes only to IT Staff and Administrator.
FR-14	Provide Administrator user list, name/email search, optional single-role filter, create and edit.
FR-15	Support activation/deactivation and new initial passwords; enforce unique emails, one role, self-deactivation and last-admin safety.
FR-16	Deliver reusable Zen Green screens, usable desktop/tablet/mobile layouts, accessible controls and meaningful feedback.
FR-17	Provide safe validation, forbidden/not-found/conflict/failure responses without disclosing private records or credentials.
FR-18	Maintain AC-to-test traceability, migration/regression evidence, peer review, AI-use records and final-main submission evidence.

5. Business Rules

Authentication and identity

- **BR-01:** Only active users with valid credentials authenticate. Wrong passwords, unknown emails and inactive accounts share 401 `INVALID_CREDENTIALS` and the message "Unable to sign in. Check your credentials or contact your administrator." Do not reveal which condition occurred.
- **BR-02:** `mustChangePassword=true` allows only current user, CSRF retrieval, password change and logout. All other application APIs return 403 `PASSWORD_CHANGE_REQUIRED`; frontend routing alone is insufficient.
- **BR-03:** Identity comes from the server session. Ignore `X-Requester-Id` entirely; never fall back to it. Reject client-supplied identity/system fields in mutation bodies. Requester list/detail queries always constrain by the authenticated ID.
- **BR-04:** Public Comments are visible to the owning Requester, IT Staff and Administrator. Internal Notes are visible only to IT Staff and Administrator. A Requester's DTO never contains notes, note counts or note snippets.

- **BR-05:** Apparent resolution is an owning Requester's indication only; it does not change status or assign responsibility. Only IT Staff formally resolve/close in this contract.
- **BR-06:** Every user has exactly one role: REQUESTER, IT_STAFF, ADMINISTRATOR. No implied role hierarchy; the matrix below is authoritative.
- **BR-07:** Email is trimmed and lowercased before validation/storage/lookup, at most 254 characters, with a valid local part and domain; no provider-specific dot/plus rewriting. Database uniqueness is authoritative. Name is trimmed Unicode NFC, 1-100 characters. Lengths in this contract use Unicode code points unless stated otherwise.
- **BR-08:** Initial/new passwords contain 15-128 characters and at most 512 UTF-8 bytes, with no trimming, silent normalization, composition rules or truncation. Reject all-whitespace values; accept spaces, Unicode and pasted passphrases. Confirmation must match exactly; the new password must differ from the current password. These are project decisions, not exact handout limits.
- **BR-09:** Use asynchronous Node `crypto.scrypt`, random salt of at least 16 bytes, 64-byte derived key, $N=131072$, $r=8$, $p=1$, and `maxmem=256 MiB`; store a versioned parameter/salt/hash string. Compare equal-length derived keys using `timingSafeEqual`. Bound concurrent hashing to two jobs; do not weaken costs in production code for tests. Passwords/hash strings never enter logs, DTOs or URLs.
- **BR-10:** Use database-backed opaque sessions: 32 random bytes in a host-only `HttpOnly` cookie, only its SHA-256 digest in the database. Absolute lifetime is 8 hours (15 minutes for initial-password sessions), with no sliding renewal. Rotate token after login and successful password change. Logout revokes server state and clears cookie. All user sessions are revoked on password reset/change, role change or activation change; a successful self password change receives one new session. Re-read user state on every request.
- **BR-11:** Cookie/CORS/CSRF behavior is fixed in `api-spec.md`. No session token or password in local/session storage. On `logout/401/account change`, clear `ticket/attachment/queue/user` caches, pending creation keys and legacy `toktickit.requester` state. Never auto-replay a failed mutation after signing in.
- **BR-12:** In the single-process local lab server, enforce 5 failed logins per normalized email and 30 failed logins per client IP per fixed 15-minute window; the next attempt returns 429 and `Retry-After` until expiry. Unknown/inactive users count identically. Use a dummy password hash for credential comparisons of unknown users. Limit password-change attempts to 5 failures per session per 15 minutes. Bound and expire limiter entries; restart resets these local counters, not sessions. No permanent lock/unlock feature.

Ticket access and workflow

- **BR-13:** `requesterId` is immutable historical authorship. Ticket owner is a separate nullable `ownerId`. Eligible new owners are active IT Staff or Administrators. Admin eligibility does not grant operational permissions.
- **BR-14:** IT Staff may operate any ticket, including a ticket assigned to another eligible user. Claim succeeds only when unassigned; a competing claim returns 409 `TICKET_CONFLICT`. Reassignment and clearing ownership require explicit confirmation. Clearing an owner is permitted only in `NEW`, `OPEN` or `REOPENED`.
- **BR-15:** Preserve `requestedPriority`; initialize/backfill `itPriority` from it and make IT Priority non-null. IT Staff can set `LOW/MEDIUM/HIGH` on non-terminal tickets. Administrator can also update IT Priority as the handout expressly permits, but has no other ticket mutation rights in this project's matrix.
- **BR-16:** Each ticket has an integer `version`, initially 1. Assignment, priority, status and resolution-indication mutations require `expectedVersion` and atomically increment it plus `updatedAt`. Mismatches return 409 `TICKET_CONFLICT` without overwriting. Comment/note appends update `updatedAt` but not this operational version, so concurrent conversation does not unnecessarily block operations.
- **BR-17:** Status updates follow the matrix below. Same-status writes and unlisted transitions are invalid. An active eligible owner is required on entry into `IN_PROGRESS`, `WAITING_FOR_REQUESTER` or `RESOLVED`. `CLOSED` requires a prior `RESOLVED` status. `Actions Taken` is not a prerequisite in Lab 3.
- **BR-18:** Requester resolution indication is allowed in `OPEN`, `IN_PROGRESS`, `WAITING_FOR_REQUESTER` and `REOPENED`. Store `requesterResolvedAt` using server time. Repeating the indication at the current version returns the existing result without incrementing version; a stale version still conflicts. Reset the indication when a ticket becomes `REOPENED`. No separate custom status is created.
- **BR-19:** `CLOSED` and `CANCELLED` tickets are read-only for assignment, priority, resolution indication and conversation. Reopening `CLOSED` is the one permitted exception; `CANCELLED` is terminal. `RESOLVED` still accepts conversation, assignment and priority, but its owner cannot be cleared.

- **BR-20:** Requesters retain Lab 2 attachment upload/download/soft-removal rules on owned tickets, including historical/terminal tickets. IT Staff and Admin can read/download permitted existing attachments on any ticket, but cannot upload/remove them. Removed/unavailable bytes remain inaccessible. Existing validation, safe filenames, limits, compensation and idempotent ticket creation remain in force.
- **BR-21:** Comments and notes are separate append-only resources. Content is Unicode NFC, CRLF-to-LF normalized and trimmed, 1-2,000 characters. Reject empty/blank/over-limit values and client author/time/visibility overrides. Render escaped plain text with line breaks; no HTML/Markdown execution. Each entry has UUID, ticket ID, author ID and server creation time. No edit/delete endpoints.
- **BR-22:** Conversation lists are oldest-first by `(createdAt,id)` with `page/pageSize` metadata. No cross-ticket leakage. A failed post retains text, disables duplicate clicks while pending and does not automatically retry an uncertain append; reload entries before the user chooses to retry.
- **BR-23:** Queue search matches number/summary/description; filters and sorting are defined in `api-spec.md`. Role and ownership authorization applies before returning totals, lookup data, record existence or validation details. Missing and non-owned Requester resources have the same safe 404 response.

Administration and data preservation

- **BR-24:** Only Administrators list/search/create/edit users and set initial passwords. Create requires one role, active state and an initial password. Password issuance is manual in this local lab: admin enters and communicates it outside the app; the API never returns passwords. No email delivery.
- **BR-25:** Admin cannot deactivate their own account. No operation may deactivate or demote the last active Administrator. All admin create/edit/reset mutations serialize through one transaction-scoped database advisory lock, recheck actor authorization inside the transaction, check target version and invariants, then commit. Concurrent requests cannot leave zero active admins.
- **BR-26:** Prevent deactivation or role change away from IT_STAFF/ADMINISTRATOR for a user owning tickets outside CLOSED/CANCELLED (`409 USER_HAS_ACTIVE_TICKETS`). IT Staff must reassign those tickets first. Historical terminal assignments, requester authorship and comment/attachment authors remain preserved even after role/activity changes.
- **BR-27:** Admin edits use integer user `version` for optimistic concurrency. Increment it on account edit, password change or reset. Reset sets `mustChangePassword=true`, invalidates all sessions and never returns the new password/hash. Ordinary edits do not reset passwords. Admin self-demotion is allowed only when another active Admin remains and BR-26 permits it; it invalidates the current session.
- **BR-28:** Migration preserves IDs, existing email/name/timestamps, tickets, categories, systems, attachment metadata/bytes and idempotency records. Preflight normalized-email collisions; stop with an actionable non-secret report instead of merging/deleting users. No development-database reset.
- **BR-29:** Seed is local/test-only and idempotent: at least 4 active + 1 inactive Requesters, 3 active + 1 inactive IT Staff, and 1 active Admin. Use deterministic seed IDs, varied queue statuses/priorities/ownership and harmless conversation examples. Reruns do not reset existing passwords, reactivate users or overwrite user edits/tickets.
- **BR-30:** Automated migration/regression tests run only in an isolated guarded test database and upload directory. Test evidence reports actual commands, branch/commit, counts and results; pending or blocked checks never become Pass.

Authorization matrix

All permissions require an active, non-expired, password-changed session, except the four restricted authentication operations. Own means `ticket.requesterId == session.userId`.

Operation	Requester	IT Staff	Administrator
Current user, CSRF, logout, password change	Yes, including restricted session	Same	Same
Active category/system references	Yes	Yes	Yes
Create ticket / My Tickets	Own	No	No
Requester detail	Own	No	No
Shared queue / staff detail	No	Yes	Read-only

Operation	Requester	IT Staff	Administrator
Eligible owner lookup	No	Yes	No
Claim / assign / clear owner	No	Yes	No
Update IT Priority	No	Yes	Yes
Change status	No	Yes	No
Indicate apparent resolution	Own	No	No
Read Public Comments	Own	Any ticket	Any ticket
Append Public Comments	Own, non-terminal	Any non-terminal	No
Read Internal Notes	No	Any ticket	Any ticket
Append Internal Notes	No	Any non-terminal	No
Attachment metadata/download	Own	Any ticket	Any ticket
Attachment upload/soft-remove	Own, Lab 2 rules	No	No
User list/create/edit/reset	No	No	Yes

Admin's landing page remains User Management. A secondary Ticket Lookup route exposes the narrow read/priority rights required by the handout; it does not show IT Staff claim/status/post actions. This resolves the handout's conceptual role separation and explicit Admin note/priority/owner permissions without granting all staff powers.

Status transition matrix

Only IT Staff can execute the following. Values use API enum spelling; UI displays title-case labels. All require `expectedVersion`.

From	Permitted next statuses
NEW	OPEN, CANCELLED
OPEN	IN_PROGRESS, WAITING_FOR_REQUESTER, CANCELLED
IN_PROGRESS	WAITING_FOR_REQUESTER, RESOLVED, CANCELLED
WAITING_FOR_REQUESTER	IN_PROGRESS, RESOLVED, CANCELLED
RESOLVED	CLOSED, REOPENED
CLOSED	REOPENED
REOPENED	OPEN, IN_PROGRESS, WAITING_FOR_REQUESTER, CANCELLED
CANCELLED	None

Targets RESOLVED, CLOSED, REOPENED and CANCELLED require a confirmation dialog and `confirmed=true`; there is no required resolution-summary/Actions Taken field. Claim and assignment do not automatically change status. All nonlisted role/state combinations are denied.

6. UI Summary

The complete screen contract, dimensions, components, states and visual checklist are in [ui-spec.md](#). The user explicitly requested polished UI that matches the assignment. Visual consistency and usable states are acceptance requirements. Avoid reproducing excluded screenshot controls such as reset-email, Service Actions or unnecessary admin pagination.

7. Data Model and Migration

Model	Required increment
User	Evolve/rename RequesterUser, preserving UUIDs and timestamps; normalized unique email, name, role, isActive, passwordHash, mustChangePassword, version=1. Existing users default REQUESTER.
AuthSession	UUID, unique tokenHash, userId FK, csrfToken (32 random bytes encoded), createdAt, expiresAt. No raw session token. Index userId and expiresAt; FK restricts user deletion.
Ticket	Preserve fields/FKs and creation records; add nullable ownerId -> User, version=1, nullable requesterResolvedAt; make itPriority required after backfill; expand TicketStatus enum.
PublicComment / InternalNote	Separate models with UUID, ticketId, authorId, content, createdAt; index (ticketId, createdAt, id); restrictive FKs.
Attachment / TicketCreateRequest	Retarget User relations while preserving original IDs and physical columns, including uploadedByRequesterId/removedByRequesterId; legacy names remain internal history.

Queue indexes: retain Lab 2 requester indexes; add (currentStatus, updatedAt), (ownerId, updatedAt) and (itPriority, updatedAt). User email unique index is authoritative; no broad text-search infrastructure needed for the lab dataset.

Migration sequence: (1) back up development database/private files and record row counts/relationships; (2) preflight normalized emails; (3) rename table and preserve FKs, add schema fields/models/enums; (4) backfill normalized email, REQUESTER, versions, IT Priority; (5) run an idempotent initialization script for users with missing hashes, consuming an ignored local JSON map of user ID to initial password; validate every target/password and hash before a transaction, set mustChangePassword, never print passwords; (6) verify no missing hashes, apply NOT NULL and unique constraints; (7) run safe seed, reconcile counts/IDs/attachment checksums and ownership. An interrupted run safely resumes; no login is served during the maintenance migration. The input map is deleted by its owner after secure local distribution. Test fixtures use synthetic credentials only.

Existing seed/test consumers are updated to User explicitly. Lab 2 tests of selector/header semantics are replaced with authentication tests; the behavior they previously protected is retained in migrated regression tests. Legacy GET /api/requesters is removed (404); legacy UI /select-requester redirects to login without returning the user directory.

8. API Contract

Foundation implementation refinement for peer review: the migration sequence in section 7 now enforces a non-null passwordHash immediately, using a non-verifiable !INITIAL_PASSWORD_REQUIRED marker until the same private-map initializer completes. No default credential is embedded in the migration; maintenance continues until all markers are replaced. AuthSession also stores userVersion to invalidate stale sessions on account changes. Rationale, actual regression coverage and remaining rollout checks are in [foundation.md](#). This refines the intermediate schema mechanics without relaxing credential initialization or data-preservation requirements.

See [api-spec.md](#) for exact routes, body/response shapes, cookies, CSRF, limits, query handling and safe errors. Lab 2 APIs retain their resource shapes except explicit authenticated identity, non-null IT Priority and additive workflow fields.

9. Acceptance Criteria

ID	Observable acceptance criterion
AC-01	Active valid login sets the session cookie and safe role/user response; unknown, wrong-password and inactive attempts have indistinguishable 401 bodies.
AC-02	Initial-password login permits only auth operations; direct application API access fails until valid change rotates the session and permits the role landing page.
AC-03	Password boundary/confirmation/current-password checks and failed-attempt limits reject invalid inputs safely without plaintext storage or logs.

ID	Observable acceptance criterion
AC-04	Logout, expiry, reset, role/activity changes invalidate old sessions; refresh/back navigation displays no cached protected data; CSRF/origin violations fail.
AC-05	Every role/operation in the authorization matrix is exercised directly; forged requester IDs never change identity and ownership failures do not disclose existence.
AC-06	Migration preserves Ticket/Attachment/CreateRequest IDs, authorship, bytes and relationships, backfills priority and initializes mandatory-change credentials; collisions stop migration safely.
AC-07	Repeated seed runs preserve edits/passwords and satisfy minimum active/inactive roles plus realistic tickets/conversation.
AC-08	Authenticated Requester creates tickets with the existing validation/idempotency behavior, searches only own records and sees no selector or client-derived identity.
AC-09	Owned attachment upload/download/soft-removal, limits, unavailable/removed states and compensation continue; staff/admin get safe read access only.
AC-10	Queue returns the documented search/filter/rank/sort/page subset and metadata; invalid queries fail; empty and no-results differ.
AC-11	Staff detail presents complete historical data, active/removed attachment states and permitted controls; Admin detail exposes only read and IT Priority rights.
AC-12	Claim/reassignment/clear-owner enforce eligible accounts/state/version; concurrent claim produces one winner and one safe conflict.
AC-13	New/migrated IT Priority equals Requested Priority initially; only Staff/Admin can change IT Priority and the requested value remains unchanged.
AC-14	Every allowed and disallowed status edge, owner precondition, same-state rejection, terminal rule and confirmation is tested; stale updates never overwrite.
AC-15	Owning Requester indicates apparent resolution only in allowed states; status is unchanged, duplicates do not duplicate state, and reopen clears the indication.
AC-16	Public Comments validate and append with server author/time, deterministic pagination and safe plain-text rendering; non-owner and terminal writes fail.
AC-17	Internal Notes never appear in Requester payloads/counts/navigation; direct reads/writes are denied; Staff can append and Admin can read only.
AC-18	Admin list/search/role filter and create/edit work with exactly one valid role, normalized unique email and documented field errors.
AC-19	Admin initial-password reset invalidates sessions and requires change at next login without sending/returning email or plaintext secrets.
AC-20	Self-deactivation, removing last active Admin, assigned-user deactivation/demotion and stale edits are blocked, including concurrent requests.
AC-21	Login, password change, Requester detail, queue, staff detail and admin screens provide busy/validation/success/empty/no-results/forbidden/not-found/conflict/safe-failure feedback where meaningful.
AC-22	Major screens pass desktop/tablet/mobile visual review with consistent tokens, readable hierarchy, distinct notes/comments and no clipping/overlap/page overflow.
AC-23	Keyboard navigation, labels, error focus/announcements, dialog focus restoration, touch targets and non-color status communication work.
AC-24	Unit/API/UI/regression/E2E results, screenshots, review history and AC mappings are captured honestly from final main and linked in the nine-part submission.

Each AC maps to planned tests in [tests.md](#); planned filenames are not yet evidence of implemented tests.

10. Definition of Done

- [] Reviewed contract is internally consistent; all FR/BR/AC items are implemented or explicitly revised with rationale and peer review.
- [] Migration preserves development data and is demonstrated on isolated existing-Lab-2 fixtures; seed is repeatable without resetting accounts.
- [] Authentication, direct API authorization, requester regression, staff operations and minimal administration meet this contract.
- [] All planned relevant tests pass with no required skipped/disabled tests; failures are fixed rather than hidden by weakening assertions.
- [] Both production builds and final-main unit/API/UI/regression/E2E checks pass; commands/commit/results are recorded.
- [] Desktop/tablet/mobile screenshots and completed human visual checklist demonstrate the requested UI quality and accessibility.
- [] README setup/migration/initial-password distribution/test/build instructions and .gitignore are correct; no secrets/local uploads/generated noise in Git.
- [] Six Issues use the existing Backlog -> Specified -> Started -> PR Review -> Fixing -> Done workflow as appropriate; each PR has its formal Development-panel issue link.
- [] Feature PRs 1-5 target lab3-staging; approving peer reviewer merges after a real review. Issue 6 uses the release PR from lab3-staging to main, avoiding a seventh planned review round.
- [] reviewer.md records real reviewed commits, feedback, responses, approvals and merges. Do not invent approval or send review requests without the user's authorization.
- [] ai-use.md grows to 6-10 real selected prompts and a student-authored reflection. Initial log is intentionally incomplete.
- [] Submission is one concise PDF, Answer Part 1 through Answer Part 9 in order, working links/readable screenshots; final main is authoritative.

11. Decisions and Review Boundaries

This draft chooses session cookies over client-stored bearer tokens for straightforward revocation and current-role checks in the existing Express/PostgreSQL app. Scrypt is available in the existing Node runtime; its parameters follow the fallback guidance in the [OWASP password storage cheat sheet](#) and the [Node crypto API](#). Cookie/session and CSRF decisions use the [OWASP session guidance](#) and [CSRF guidance](#), consulted 2026-09-08. These references inform implementation decisions; they do not add excluded identity-management features.

Before implementation, peer review should specifically check Admin's narrow ticket permissions, status transitions/owner requirements, terminal conversation versus attachment behavior, 15-character passphrases, session revocation, initial-password migration and assigned-user deactivation rules. These are explicit project decisions rather than unstated assumptions.

The six-work-item dependency plan and submission mapping are in [issue-plan.md](#). Runtime feature implementation begins after the engineering contract's review; this draft is a reviewable work product, not a completed application.

Companion [API contract](#).

Answer Part 3

Test plan, traceability and execution evidence

Final-main output is PENDING. The 389 tests, 17 browser journeys and two production builds below were verified on staging and independently repeated by the reviewer. They must not be represented as runs on main. Full final-main console outputs will be included after the actual release merge.

Rendered source: <docs/lab-03/tests.md> - complete document; dated historical entries retained.

Lab 3 Test Plan and Traceability

Current integrated record: <system-verification.md>. It maps consolidated files, records failed attempts and corrections, and distinguishes staging checks from final-main acceptance. The matrix's original scenario descriptions are acceptance intent; use the actual named test cases and scope notes when stating what a run proves.

Integrated verification - Issue #29, 2026-09-25

- `npm test`: **389 passed, 36 files, zero skipped**, exit 0, 194.97 seconds, started 23:35:56 Bangkok. Commit 5a0934e8e4c89c75f03b5817bfc48fdf1cd30479; fresh guarded database `lab3_verification_unit_test`.
- `npm run test:e2e:capture:lab3`: **17 browser journeys passed**, zero skipped, exit 0, 3.8 minutes; isolated `lab3_verification_test`, ports 3400/5400. Captured **109 PNGs** with verified SHA-256 values from application/browser source 08d37115e4f8c3367642a8753260044fb3181975; the later commit only completes a jsdom test stub.
- Both production builds passed after the dialog correction. Local Markdown links: 157 valid. Diff whitespace check passed.
- Initial failed/interrupted runs, actual coverage mapping, synthetic versus real evidence and agent visual observations are retained in the integrated record. This is staging author verification, not peer approval or final-main acceptance.

Status: The matrix began as a plan; its filenames now point to the implemented suites. See `system-verification.md` for current consolidated coverage, actual results, simulated evidence and remaining final-main/human acceptance. Historical dated results remain below.

Administrator verification - Issue #28, 2026-09-20

Peer correction verification - 2026-09-21

Reviewed head: 88922cb. Datakung's independent run passed 378 tests and both builds but had one ambiguous status-locator failure in the full browser suite; its passing targeted rerun did not establish a clean full browser run. The two findings and links are recorded in `reviewer.md`.

- Before the navigation fix, all five new App-level regression cases in `AdminNavigation.test.tsx` failed because navigation unmounted the dirty form without the required prompt.
- After the fix, `npx vitest run client/tests` passed **85 cases across 13 files**, zero skipped, 74.36 seconds (started 15:07:31 Bangkok). Tests use mocked requests with a guarded synthetic URL, not a database.
- `npx playwright test --config playwright.staff.config.ts` passed **all 13 browser journeys**, zero skipped, in 2.6 minutes. This is one complete run, including the new native Back/Forward case and both corrected success-notice assertions. No fixed waits, arbitrary first matches or retries were added.
- Both production builds passed. The final staged diff check passed.
- Browser execution used isolated `lab3_admin_test` with ports 3300/5300. Existing development data was not migrated or reset. Docker's repeated stale socket startup failure was recovered by backing up its verified socket-only runtime

directories.

The corrected router asks before header/password-page navigation and restores blocked history traversal before prompting. Cancel retains the draft; Confirm replays the intended Back/Forward entry. Tests also verify that logout, session expiry and mandatory password change bypass a pending prompt. This is a frontend/test correction; the full 378-case API/unit result below remains historical and was not claimed as rerun for this patch.

Based on the approved PR #33 merge f13469c; branch codex/lab3-4-user-administration targets lab3-staging. See [implementation and contract mapping](#).

Check	Actual result
Full Vitest regression suite	378 passed in 34 files , zero skipped; started 16:15:29 Bangkok, 263.22 seconds
Focused administrator API suite	25 passed , real PostgreSQL and HTTP middleware; includes concurrent duplicates, stale versions, last-admin protection and account changes racing claim/assignment/start/resolve
Client suite	80 passed in 12 files ; includes six new administrator UI cases; the full regression run above includes them again after the final focus correction
Full browser suite using playwright.staff.config.ts	12 passed , zero skipped, about two minutes; ten inherited journeys plus account lifecycle and four-width administrator visual checks
Server and client production builds	Passed; client rebuilt after modal-focus and layout corrections
Responsive checks	Directory, editor and reset dialog at 1440, 834, 390 and 320 widths; no horizontal overflow

Vitest used guarded lab3_test; browser journeys used newly created lab3_admin_test on loopback port 55433, with client/API ports 3300/5300. No development database migration/reset. Both use the local test-only PostgreSQL container. Docker initially failed on inaccessible stale runtime sockets; only the socket directories were backed up so Docker could recreate them. No factory reset, container removal or volume removal occurred.

The first focused browser run passed responsive checks but failed the assertion that Escape restores focus to the reset opener. React Strict Mode exposed the modal cleanup timing. The fix preserves the original opener and closes the native dialog before restoring focus after unmount; the same assertion passed in the final full run. Screenshot inspection also found cramped desktop Edit labels while the side form was open; the page width and button wrapping were corrected before the final capture. No failing assertions were removed.

Evidence: [12 administrator screenshots](#). Agent visual inspection covered the desktop side form, tablet directory cards, mobile editor and 320px reset dialog. These observations are not a student visual approval or independent peer review. #29/#30 still own full-system/final-main acceptance.

Contract: [specification.md](#), [api-spec.md](#), [ui-spec.md](#).

1. Test-first workflow and environment

Each feature Issue selects mapped FR/BR/AC/Test IDs, writes tests that fail for the intended missing behavior, records a concise red result, implements, then refactors with green tests. Plan tests before or alongside implementation, not after reading generated tests. Changes to requirements and planned assertions are reviewed together; no weakening authorization or migration tests to manufacture green results.

Use existing Vitest, Supertest, React Testing Library and Playwright. Database tests use the existing TEST_DATABASE_URL guard and a dedicated test database distinct from development. Migration fixtures use a separate temporary guarded database/schema with Lab 2 data and isolated upload storage; never reset development. Test setup/teardown must reject unsafe URLs/paths before destructive operations. Hash tests use real configured costs in focused cases; unrelated UI tests may mock HTTP. API/security tests must not bypass authentication/authorization middleware.

2. Planned tests

Every row initially has Final = Planned. Multiple test cases within a row cover its full expected-result statement, not just one happy path.

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
UNIT-01	Unit	AC-03	Email/name normalization, 15/128 code-point and 512-byte password boundaries, no truncation, confirmation, whitespace and real salted script verification; wrong passwords fail.	server/tests/lab-03/auth.unit.test.ts	Implemented; see integrated execution/scope
UNIT-02	Unit	AC-03, AC-04	Fixed-window limits and expiry with controlled clock, safe dummy-hash path, random session/digest generation and restricted/full expiry.	server/tests/lab-03/auth.unit.test.ts	Implemented; see integrated execution/scope
UNIT-03	Unit/API	AC-10	Strict queue keys/types/duplicates, rank ordering, pagination and deterministic tie-break parsing.	server/tests/lab-03/staff-workflow.api.test.ts + server/tests/lab-02/ticket-query.unit.test.ts	Implemented; see integrated execution/scope
UNIT-04	API	AC-12, AC-14, AC-15	Enumerate all eight-by-eight status pairs, owner/terminal/confirmation preconditions and requester indication states.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
UNIT-05	API	AC-16, AC-17, AC-18	Comment normalization/length and admin fields/one-role validation including Unicode and unknown properties.	server/tests/lab-03/staff-workflow.api.test.ts + server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-01	API	AC-01, AC-03	Active valid login; unknown/wrong/inactive same safe 401; normalized email; invalid body and failed-attempt 429/Retry-After.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-02	API	AC-02, AC-03	Initial-password gate on every protected endpoint; correct change, wrong current password, mismatch, same-password and exact boundaries; token rotation.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-03	API	AC-04	me/logout/idempotent logout/expiration and old-cookie rejection after change/reset/role/activity changes; cookie flags, no-store, no secrets.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-04	Security/ API	AC-04, AC-05	Pre-auth and session CSRF, missing/wrong token/Origin, credentialed CORS allowlist, hostile Origin and legacy header-only attempts.	server/tests/lab-03/authorization.api.test.ts	Implemented; see integrated execution/scope
API-05	Security/ API	AC-05, AC-09, AC-17	Table-driven full role/operation matrix incl. Admin's limited detail/priority rights; owned/non-owned/missing ticket/file; response/private-count leakage; requester header/body spoof.	server/tests/lab-03/authorization.api.test.ts	Implemented; see integrated execution/scope

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
API-06	API	AC-10	Search each field, AND filters, each owner mode, priority ranks both ways, each sort/ties, pages/totals/out-of-range, invalid/unknown/repeated params.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-07	API	AC-11, AC-12	Safe detail/eligible owners, claim and reassign/clear; reject inactive/wrong-role targets and terminal/clear-state violations; preserve requester identity.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-08	Concurrency/API	AC-12, AC-13, AC-14	Two independent requests claim/update same version: one succeeds, loser 409, no overwrite/500; owner deactivate versus assign/start/resolve uses shared lock.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-09	API	AC-13, AC-14	Priority changes by Staff/Admin only; requested priority unchanged; every status edge, confirmation and active-owner prerequisite enforced by real API.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-10	API	AC-15	Owned indication, permitted/disallowed states, no status change, repeat/current versus stale version, reopen clearing and non-owner denial.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-11	API	AC-16, AC-17	Append/list public and internal entries, author/time from server, Unicode/blank/length/HTML-as-text, deterministic pages, terminal writes, absent edit/delete and no Requester note leakage.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-12	API	AC-18	Admin list name/email search, role filter/no-results, create and complete edit, email normalization, duplicate/invalid email/role/types and concurrent duplicate creation.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-13	API	AC-19	Initial-password issuance/reset including self-reset, force change, immediate old-session invalidation and no password/hash in response/log.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-14	Concurrency/API	AC-20	Self-deactivation/last-admin/stale-edit protection; simultaneous demotions/deactivations still leave one active Admin; assigned-user deactivation/demotion conflicts; actor rechecked after lock.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-15	Failure/API	AC-21	Inject auth/queue/detail/conversation/admin database failures; safe 500/correlation and no sensitive output; transactional updates roll back.	server/tests/lab-03/safe-errors.api.test.ts	Implemented; see integrated execution/scope
MIG-01	Migration/integration	AC-06	Apply staged migration to populated Lab 2 fixture; compare IDs/counts/FKs/create-request hashes/attachment metadata and byte checksums; backfill priority and mandatory-change credentials.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
MIG-02	Migration /integration	AC-06	Normalized email collisions/missing credential map fail without data loss; interrupted initializer resumes; final non-null constraints hold.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope
MIG-03	Seed/integration	AC-07	Seed twice, edit password/account/ticket between runs; preserve edits and relationships, satisfy active/inactive role counts and meaningful queue/conversation distribution.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope
REG-01	Regression/API	AC-05, AC-08	Rework Lab 2 create/list/detail tests to authenticated agents: ownership, validation, concurrent idempotency, filters and historical references preserved.	server/tests/lab-02/create-ticket.api.test.ts + server/tests/lab-02/my-tickets.api.test.ts + server/tests/lab-02/ticket-detail.api.test.ts	Implemented; see integrated execution/scope
REG-02	Regression/API	AC-09	Authenticated attachment MIME/signature/filename/size/count/concurrent-upload/compensation/removal/unavailable lifecycle; exact file hashes, Staff/Admin read-only access, authorization before storage.	server/tests/lab-02/attachments.api.test.ts	Implemented; see integrated execution/scope
UI-01	UI	AC-01, AC-03, AC-21, AC-23	Login fields/show password/validation/busy/generic invalid and inactive feedback/rate limit/failure; submit focus and labels.	client/tests/lab-03/Login.test.tsx	Implemented; see integrated execution/scope
UI-02	UI	AC-02, AC-03, AC-21, AC-23	Mandatory-change guard, rules/confirmation/current-password error, busy/success/failure, no bypass and permitted ordinary back navigation.	client/tests/lab-03/ChangePassword.test.tsx	Implemented; see integrated execution/scope
UI-03	UI	AC-04, AC-05, AC-08	Session bootstrap/expiry/logout failure/success, role links, validated return path and cache clearing; remove legacy selector/storage and never replay mutation after login.	client/tests/lab-03/ApplicationShell.test.tsx	Implemented; see integrated execution/scope
UI-04	UI	AC-10, AC-21, AC-23	Queue controls, pagination/reset, loading/empty/no-results/failure, matching-query retained data, explicit detail link and keyboard usability.	client/tests/lab-03/StaffWorkflow.test.tsx	Implemented; see integrated execution/scope
UI-05	UI	AC-11, AC-12, AC-13, AC-14, AC-21	Detail fields, owner/priority/status controls, confirmations, Admin restriction, active/removed/unavailable files, read-only/forbidden/not-found/failure/conflict.	client/tests/lab-03/StaffWorkflow.test.tsx + client/tests/lab-03/ConversationRecovery.test.tsx	Implemented; see integrated execution/scope
UI-06	UI	AC-16, AC-17, AC-21, AC-23	Separate drafts/private notice, escaping malicious content, post busy/failure/uncertain retry, history pagination and keyboard tabs; no Admin composer.	client/tests/lab-03/StaffWorkflow.test.tsx + client/tests/lab-03/ConversationRecovery.test.tsx	Implemented; see integrated execution/scope
UI-07	UI	AC-08, AC-09, AC-15, AC-17	Requester detail/public comments/indication state and unchanged actual status, attachment continuity; no internal-note controls/data.	client/tests/lab-02/RequesterTicketDetail.test.tsx + client/tests/lab-03/StaffWorkflow.test.tsx	Implemented; see integrated execution/scope

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
UI-08	UI	AC-18, AC-19, AC-20, AC-21, AC-23	Admin list/search/filter/create/edit/reset, password clearing, inline safety/duplicate/conflict errors, own session invalidation, dialog focus/discard behavior.	client/tests/lab-03/UserManagement.test.tsx	Implemented; see integrated execution/scope
STYLE-01	UI style	AC-22, AC-23	Shared Zen Green tokens, primary/readonly/badge/error/focus conventions, private composer separation and absence of excluded controls.	client/tests/lab-02/ZenGreenStyles.test.tsx + e2e/lab-03/system-verification.spec.ts	Implemented; see integrated execution/scope
RESP-01	Responsive	AC-22, AC-23	Table/card/panel stacking and long labels/filenames/descriptions at 1440/834/390 and 320 widths; no page overflow and usable actions.	e2e/lab-03/system-verification.spec.ts + e2e/lab-03/staff-ticket-flow.spec.ts + e2e/lab-03/admin-users.spec.ts	Implemented; see integrated execution/scope
E2E-01	E2E	AC-01, AC-02, AC-03, AC-04, AC-05	Real login/invalid/inactive/first-change/logout; old-cookie API access rejected; all role landing pages and restricted links.	e2e/lab-02/authentication.spec.ts + e2e/lab-03/system-verification.spec.ts	Implemented; see integrated execution/scope
E2E-02	E2E	AC-08, AC-09, AC-10, AC-11, AC-12, AC-13, AC-14, AC-15, AC-16, AC-17	Requester creates with attachment; Staff searches/claims/changes priority/status/posts public/private; Requester sees public only and indicates resolution; Staff resolves/closes/reopens.	e2e/lab-03/staff-ticket-flow.spec.ts	Implemented; see integrated execution/scope
E2E-03	E2E	AC-04, AC-18, AC-19, AC-20	Admin creates/edits/resets user; user forced to change; duplicate/self/last-admin/assigned-owner guards; non-Admin denial.	e2e/lab-03/admin-users.spec.ts	Implemented; see integrated execution/scope
VIS-01	Visual/manual + capture	AC-21, AC-22, AC-23	Capture all ui-spec scenes at three viewports and inspect hierarchy/privacy/states/focus/clipping/overlap; record per-scene result and correction.	e2e/lab-03/system-verification.spec.ts + e2e/lab-03/staff-ticket-flow.spec.ts + e2e/lab-03/admin-users.spec.ts + docs/lab-03/ui-spec.md	109 captures; agent inspection recorded; final human approval pending
REL-01	Release/manual	AC-24	Run full guarded suite/builds on final main; map real outputs/screenshots/PRs/commit and nine PDF parts; check links and all Issues Done only on completion.	docs/lab-03/tests.md + docs/lab-03/reviewer.md	Planned

3. Feature ownership and regression policy

Work item 2 owns UNIT-01/02, API-01..05 for its implemented endpoints, MIG-01..03, REG-01/02 and UI-01..03. Work item 3 owns UNIT-03..05 (conversation portion), API-06..11, UI-04..07. Work item 4 owns admin UNIT-05, API-12..14 and UI-08. Each feature extends API-02/04/05 with its newly introduced protected endpoints and implements its API-15 failure cases, style and responsive checks. AC-05's complete role/operation matrix is only marked Pass once all endpoint increments are integrated; the foundation PR records its narrower implemented coverage explicitly. Work item 5 completes cross-feature E2E/visual checks, not a delayed first pass at feature tests. Work item 6 owns REL-01.

Old Lab 2 selector/header-specific assertions become obsolete and are replaced explicitly. Preserve all still-relevant tests and update their login setup/expected initial IT Priority deliberately; document replacements so deleted selector tests cannot hide lost requester/attachment protection. Existing Lab 1 category/system UI assumptions may need authenticated setup; health remains public. Unchanged tests must keep running.

4. Verification commands and evidence

Planned commands use existing root scripts: `npm test`, `npm run test:e2e`, `npm run build:server`, `npm run build:client`, `git diff --check`. Feature-specific filters may be used during red/green cycles. Add a separate explicit Lab 3 screenshot capture script in work item 5 without changing routine test runs to overwrite curated evidence.

For each result record date, full commit SHA, branch, test-only database identifier (no credentials), command, test file/case counts, exit status and artifact path. A failed/skipped/environment-blocked check is recorded as such. Hashing/rate-limit time may be controlled in tests through clocks/adapters, but one real crypto path and actual middleware/transaction coverage remain mandatory.

Contract-only validation (work item 1)

Required checks: numbered IDs unique; every AC referenced by at least one planned test; internal Markdown links resolve; six Issue scopes cover all FR and tests; endpoint roles/status rules align across documents; no claimed feature/test/peer approval before it exists. No runtime tests are required for these documentation-only edits; this does not establish application readiness.

Author validation on 2026-09-08 for the initial contract: 18 FR, 30 BR and 24 AC IDs were unique; all 24 ACs were referenced by planned tests; all internal Markdown file links resolved across seven documents; staged `git diff --check` passed. The inherited attachment request/response and Requester sort metadata were cross-checked against baseline code. This is document validation only and leaves every runtime row Planned.

Final execution record

Final-main verification remains pending for work item 6. The table above is the original full-Lab-3 plan; the narrower foundation results below supersede its Planned status only for the scenarios explicitly exercised. Workflow/admin historical results are below; the current integrated evidence supersedes those narrower runs.

Foundation verification - Issue #26

Branch `codex/lab3-2-auth-requester`, based on approved contract merge `ec5deceea1e00fa2ddb60572fa741f284eb89796`. Test database: `lab3_test` on loopback port 55433; no development database reset/migration. Source was an uncommitted working tree during execution; final source commit is recorded in the PR.

- Full node `node_modules/vitest/vitest.mjs` run: 27 files, 187 cases passed, zero skips (132.05s, run starting 2026-09-14 23:59 Bangkok time).
- After final server guard/error additions: focused `auth.api.test.ts`, `authorization.api.test.ts` and Lab 2 `attachments.api.test.ts` verification passed 24 cases across three files, zero skips (2026-09-15 00:06, 12.84s). This includes ten newly added cases; it is not presented as a second full-suite run.
- Client and server production builds passed; server was rebuilt successfully after the final guard/error additions.
- `node node_modules/@playwright/test/cli.js test`: eight cases passed, zero skips, about one minute. Real Login/initial-password change/role landing/logout, Requester create/search/detail, cross-account Ticket/Attachment protection, Attachment lifecycle and desktop/tablet/mobile layout. Initial-password screen additionally checked at 320px.

- Earlier red results came from obsolete null IT Priority/invalid CLOSED assertions and incomplete test fixtures; these were corrected explicitly. An earlier browser run had six passes and one interrupted login during a concurrent dev-server reload. The subsequent frozen-source run passed all eight.

Actual paths: `crypto` in `server/tests/lab-03/auth.unit.test.ts`; `session/password/CSRF` in `auth.api.test.ts`; implemented role matrix in `authorization.api.test.ts`; `MIG-01..03` in `migration.integration.test.ts` (seed cases live in this file). `REG-01/02` stay in existing `server/tests/lab-02/*` suites using the real session middleware. Login/change/shell tests live in `client/tests/lab-03/`; Requester UI regressions stay in `client/tests/lab-02/`. Browser files stay in `e2e/lab-02/` for continuity, with the new `authentication.spec.ts` covering the foundation gate.

Selected screenshots: `artifacts/lab-03/screenshots/`. Agent visual inspection covered desktop Login, 320px Login/Change Password and the mobile Ticket list: readable hierarchy, visible labels/actions, no overlap or horizontal clipping. This is an agent visual check, not fabricated student/peer review. Full queue/admin scenes and the final human checklist remain work items 3-5. Migration tests preserve historical metadata and relationships but do not claim a checksum audit of the user's development upload directory.

Peer-review correction verification - 2026-09-15

Reviewed baseline: `7f2a5dd3bc57296d4c53fa4d942a767dfed791ee`. New `client/tests/lab-03/ReviewRegressions.test.tsx` covers stale CSRF on deliberate login/logout retry without automatic replay, signed-out Ticket deep links, login/password-gate remounts, role-disallowed destinations, malformed IDs, and external/encoded redirect inputs.

- Before source fix: nine new tests ran; four failed and five passed, reproducing both findings.
- After source fix: `node node_modules/vitest/vitest.mjs run client/tests` passed all 60 tests in nine files, no skips (13.24s; 09:44 Bangkok).
- `npm run build:client` and `npm run build:server`: passed.
- The test-only URL satisfies the runner guard; these client tests mock network calls and do not use PostgreSQL. Earlier database/E2E results remain historical and were not rerun for this correction.

Staff workflow verification - Issue #27, 2026-09-16

Subsequent peer correction: Datakung's review of `4196fc9` reproduced pagination recovery after a lost append response. `client/tests/lab-03/ConversationRecovery.test.tsx` adds three regression cases: saved 21st public comment, saved 21st internal note, and failed latest-page recovery across a tab switch. All three failed before the fix. After the correction, `node node_modules/vitest/vitest.mjs run client/tests` passed **74 cases across 11 files**, zero skipped, in 20.62s (2026-09-16 13:50:45 Bangkok). Both production builds passed. Tests use mocked fetch with a synthetic guarded test URL and do not access a database. Full API/E2E results below belong to the earlier implementation; they were not rerun for this frontend-only correction.

Branch `codex/lab3-3-staff-workflow`, based on `1bf45888cdf4691f198d2c3d9ca38b164b6516f0`. Commands ran on the implementation working tree, committed with its evidence as `f8c1f4971211ad2f385cf956990d021515d4a0e` in [PR #33](#). The subsequent handoff update changes documentation only. No development database migration/reset. Unit/API fixtures used the guarded `lab3_test` database; browser journeys used the newly created `lab3_staff_test`, both on loopback port 55433. The existing foundation preview was left running separately.

Check	Actual result
<code>node node_modules/vitest/vitest.mjs run</code>	31 files, 344 tests passed , zero skipped; 127.71s, started 2026-09-16 01:15:51 Bangkok
<code>npm run build:server</code>	Passed after final code changes
<code>npm run build:client</code>	Passed after final code changes
<code>node node_modules/@playwright/test/cli.js test --config playwright.staff.config.ts</code>	10 passed , zero skipped; about 1 minute, 2026-09-16. Eight retained login/Requester/attachment/responsive journeys plus two staff workflow/visual journeys
<code>git diff --check</code>	Passed

Browser invocation set `E2E_CLIENT_PORT=3200` and `E2E_API_PORT=5200` to avoid the existing preview, plus a guarded `TEST_DATABASE_URL`. The staff config includes both `e2e/lab-02` and `e2e/lab-03`, with additional synthetic staff/admin users. Default `playwright.config.ts` still runs the eight inherited journeys.

The new API suite contains 127 cases: the complete 64-edge status matrix, confirmation/owner/terminal rules, actual competing claim/priority requests, ownership and note privacy, queue validation/ranking/totals, indication repeats/reopening, and append-only Unicode/plain-text validation. Three account-lock tests observe a real waiting advisory lock in PostgreSQL before releasing a competing account change, then check assignment/start/resolve eligibility again. These test the shared lock contract; actual Administrator mutation endpoints arrive in #28. Queue/conversation failures return a safe correlation ID and avoid logging submitted content.

The new UI suite has 11 cases for deliberate filters/page reset, error/empty states, assignment confirmation, retained selections after conflict, restricted Admin controls, terminal history, separated drafts/keyboard tabs, uncertain-post refresh without automatic retry, and Requester indication. It maps UI-04..07. Existing attachment/shell test cases are retained, with their new workflow/queue child isolated; feature behavior is tested in the new suite and integrated browser journeys. Actual filenames and mappings are detailed in [staff-workflow.md](#).

Failures retained honestly: the first new API run found PostgreSQL's void advisory-lock return was incompatible with `$queryRaw`; the lock now uses `$executeRaw`. The first staff browser run passed responsive checks but failed its exact nested-label selector; it now targets the verified IT Priority combobox. The first inherited browser rerun passed seven cases and found an ambiguous user-name selector because the new owner list also contains that name; the assertion now targets the banner. The final ten-case run passed all cases. Earlier counts (136 focused, 342 full) precede the two additional lock-contention cases and are not added to the final totals.

Selected evidence: [staff-workflow screenshots](#). Twelve PNGs show queue, detail/public conversation and internal-note views at 1440, 834, 390 and 320 widths. Automated overflow checks passed at all four widths. Agent visual inspection covered the desktop queue/private detail, tablet cards and mobile/narrow detail: readable groups/actions, distinct amber private notice, wrapped long content and no horizontal clipping. These checks do not claim a student/peer visual approval or the full-system/final-main acceptance reserved for #29/#30.

Rendered source: [docs/lab-03/system-verification.md](#) - complete document; dated historical entries retained.

Integrated system verification - Issue #29

Branch: `codex/lab3-5-system-verification` → `lab3-staging`. Integrated baseline:

`2c6f79938ec17573e8727639c34e60eefbc190c5` (reviewed PR #34 merge). Date: 2026-09-25. These are author/agent checks; peer approval and final-main verification are separate.

Execution record

The first baseline regression run passed **383 cases in 35 files**, zero skips, in 406.57 seconds (17:55:39 Bangkok). Both production builds passed. The first four new responsive journeys passed at desktop/tablet/mobile/narrow widths before their conflict and keyboard scenarios were expanded.

New API-15 coverage injects failures through actual HTTP middleware for authentication, queue, detail, conversation and account listing. A real PostgreSQL transaction executes the comment append and then throws before commit; the test checks that both the append and ticket timestamp roll back. The migration fixture additionally compares the SHA-256 of a synthetic retained attachment file before/after each migration. This is test-fixture evidence, not a claim to have migrated or checksummed the user's development uploads.

Failures retained in the record:

- The first expanded browser capture passed the 13 inherited journeys, then timed out because an exact text-label selector did not match the priority select's accessible name. It was corrected to the explicit `combobox` role/name; no assertion was removed. The run was stopped after reproducing the selector issue and did not replace curated evidence.
- The next desktop run exposed Shift+Tab escaping the confirmation's action cycle. The shared confirmation now wraps Tab/Shift+Tab explicitly, closes its native dialog during cleanup and restores the original opener after unmount in Strict Mode. The reset-password dialog uses the same key handler. Browser checks retain the failing keyboard assertion and also check Escape/focus restoration.

- The first run including six new API cases passed 388/389, with the rollback fixture failing before exercising the endpoint because restoring a spy removed Prisma's proxy-provided transaction binding. The fixture now retains/restores the original bound method between cases. This was a test setup correction, not a server rollback failure.
- Image inspection caught a requester indication capture while conversation history was still loading. Capture now awaits that region's explicit ready state instead of using a delay.
- A full run concurrent with browser/build work hit the existing 30-second Prisma subprocess timeout in the migration fixture. It was stopped, not counted as a pass. The final regression runs alone after those processes finish; neither the assertion nor its timeout was relaxed.
- Reusing that interrupted run's database exposed an orphaned synthetic category fixture. The final full suite therefore uses a newly created `lab3_verification_unit_test`, without deleting or modifying development data. The same run also found that `StaffWorkflow`'s `jsdom` dialog stub implemented `showModal` but not `close`; its stub was completed to match the browser API used by the verified cleanup. Production behavior and assertions were retained.

Final browser capture passed **17/17 journeys**, zero skips, in **3.8 minutes**, exit 0. Both production builds passed after the focus correction. Capture completed at **2026-09-25 23:31:23 Bangkok** from source commit `08d37115e4f8c3367642a8753260044fb3181975`; the only dirty path at manifest creation was the newly generated screenshot directory. All 109 PNG checksums were independently verified against the manifest. The subsequent `jsdom` stub correction does not change the captured application or browser test source; final evidence commits record results separately.

Final full `npm test`: **389/389 cases in 36/36 files**, zero skips, exit **0**, **194.97 seconds**, started **2026-09-25 23:35:56 Bangkok**. Source commit: `5a0934e8e4c89c75f03b5817bfc48fdf1cd30479`. Database: freshly created `lab3_verification_unit_test`. This includes all six API-15 cases, all three migration/seed cases and the completed `jsdom` dialog stub. The captured application and browser tests are unchanged from `08d3711`.

Local Markdown links: **157 checked**, none missing. All **109** image checksums match the manifest. `git diff --check` passes. These results establish the author verification baseline for peer review; final-main verification remains pending.

Reproduction and isolation

Install dependencies in `root`, `server` and `client`, then run `npm run prisma:generate`. Configure a guarded `TEST_DATABASE_URL` using `.env.test.example`. Use separate databases for Vitest and Playwright; on resource-constrained machines run the suites sequentially. Earlier attempts used `lab3_test`; the clean final Vitest run uses `lab3_verification_unit_test`, and browsers use `lab3_verification_test`, all in the test-only PostgreSQL container on loopback port 55433. No development database reset/migration or Docker factory reset was performed.

```
npm test
$env:E2E_CLIENT_PORT = '3400'
$env:E2E_API_PORT = '5400'
npm run test:e2e:lab3
npm run build:server
npm run build:client
# Explicit evidence refresh: runs the full browser suite, copies only on success.
npm run test:e2e:capture:lab3
```

Vitest/API fixtures use real sessions and real transactions where applicable; UI component tests intentionally mock HTTP. Playwright starts its own servers. The capture manifest records baseline commit, dirty paths, timestamp and image SHA-256 values. Routine runs never overwrite curated images. Its source snapshot is author evidence; it must not be described as a peer-approved/final-main commit until the relevant review occurs.

Actual test mapping

The matrix in `tests.md` retains the original acceptance scenarios, with filenames updated to the consolidated implementation. Some acceptance rows intentionally span API, component and browser evidence rather than one isolated file.

Planned IDs	Actual evidence
UNIT-01/02, API-01-04	<code>server/tests/lab-03/auth.unit.test.ts</code> , <code>auth.api.test.ts</code> , <code>authorization.api.test.ts</code> ; session reset/role/activity also <code>admin-users.api.test.ts</code>

Planned IDs	Actual evidence
UNIT-03-05, API-05-11	server/tests/lab-03/staff-workflow.api.test.ts; retained query parsing in server/tests/lab-02/ticket-query.unit.test.ts; account-validation portion in admin-users.api.test.ts
API-12-14	server/tests/lab-03/admin-users.api.test.ts, including actual account/ticket races
API-15	server/tests/lab-03/safe-errors.api.test.ts; inherited queue and attachment failure cases
MIG-01-03	server/tests/lab-03/migration.integration.test.ts (preservation, collision/initializer and repeat seed); synthetic attachment checksum
REG-01/02	Existing server/tests/lab-02/ create/list/detail/requester-context/attachment suites, now using real session cookies
UI-01-03	client/tests/lab-03/Login.test.tsx, ChangePassword.test.tsx, ApplicationShell.test.tsx, ReviewRegressions.test.tsx
UI-04-07	client/tests/lab-03/StaffWorkflow.test.tsx, ConversationRecovery.test.tsx; client/tests/lab-02/RequesterTicketDetail.test.tsx
UI-08	client/tests/lab-03/UserManagement.test.tsx, AdminNavigation.test.tsx
STYLE-01, RESP-01	Retained Lab 2 ZenGreenStyles/ResponsiveStyles component suites; real browser state/overflow/layout checks in all three Lab 3 specs; agent image inspection
E2E-01	e2e/lab-02/authentication.spec.ts and e2e/lab-03/system-verification.spec.ts; inactive credentials/session expiry also real auth API tests
E2E-02	e2e/lab-03/staff-ticket-flow.spec.ts plus system conflict/terminal/requester captures
E2E-03	e2e/lab-03/admin-users.spec.ts; duplicate/self/last-admin/owner invariants also real Admin API tests
VIS-01	All three Lab 3 specs; e2e/lab-03/capture-evidence.mjs; image inspection below
REL-01	Pending Issue #30: reviewed release, final-main checks and final PDF

Screenshot index and visual inspection

Curated root: [system screenshots](#). [Manifest](#) enumerates the exact images and checksums. All accounts and ticket/file data are synthetic. Viewports: desktop 1440×900, tablet 834×1112, mobile 390×844, narrow 320×900.

Folder	Scenes
screenshots/	Five retained authentication captures from the existing real login/password-change journey
staff-workflow/	Real queue and filters, Staff detail and private conversation at all four widths
user-management/	Directory, current-account editor/self-protection and reset dialog at all four widths
system-states/	Login ready/invalid/validation/busy/failure, mandatory change, queue no-results/empty/failure/retry, public/private detail, real conflict, terminal/not-found, requester attachment/indication, restricted Admin detail and create validation

Filenames containing `simulated` use controlled browser responses for reproducible busy, unavailable and empty presentation states. Other system scenes use real application/API/database state. Browser assertions verify no document overflow, error focus, private-draft separation, restricted controls, conflict reload, confirmation key cycling and opener restoration. The legacy responsive suite also exercises long labels/filenames. Screenshots alone do not establish correct API authorization or complete WCAG conformance.

Agent visual inspection on 2026-09-25 covered the desktop queue and login failure, tablet account editor/create validation/terminal detail, mobile private conversation and Requester indication, and 320px reset/create validation. Full-page captures were opened and inspected, not inferred from passing geometry assertions.

- [x] Consistent green/white action hierarchy, readable headings and separated cards in the inspected scenes.
- [x] Desktop six-column queue retains priority/owner information and pagination; narrow layouts stack controls without document overflow.
- [x] Private conversation has an amber notice and distinct tab; Requester evidence contains public history only. The test asserts that a private draft never populates the public composer.
- [x] Conflict alert explains reloading while preserving the attempted choice; terminal screens keep readable history and remove the composer.
- [x] Administrator form errors wrap at 320px and focus the first invalid input; current-account editor explains the disabled Active switch. No delete/bulk/email-reset actions appear.
- [x] Dialog actions and focus rings are visible; keyboard wrapping and Escape/opener restoration are verified by the browser assertions. Narrow reset has readable warning text and masked/empty password fields.
- [x] Selected stylesheet color pairs were numerically checked using WCAG relative luminance: primary/white **6.63:1**, body/white **13.30:1**, muted/white **6.14:1**, warning badge **4.55:1**, error **6.05:1**. These five checks do not claim an exhaustive contrast audit or include disabled controls.
- [x] Captures have an exact source commit and verified PNG checksums. They are author evidence awaiting peer review.

The student/reviewer must still inspect the final reviewed version and native browser zoom before submission; no human approval or complete accessibility conformance is inferred from the agent checks. The final human checklist in ui-spec.md remains explicitly separate.

Submission boundary

[submission-draft.md](#) prepares Answer Parts 1-9. [ai-use.md](#) contains the requested Reflection draft and real selected prompts. Issue #29 does not mark the release Done, claim final-main test results or create a final PDF from unreviewed staging. Those actions remain Issue #30 after this PR's peer approval and merge.

Answer Part 4

AI assistance and Reflection

The nine selected prompts are recorded user requests. The Thai Reflection is an AI-written draft requested by the user; the student must read and adapt it before submission. This report does not assert personal understanding or testing by the student.

Rendered source: <docs/lab-03/ai-use.md> - complete document; dated historical entries retained.

Lab 3 AI Use Record

Status: Living record with nine real selected prompts, implementation/review history and a user-requested Reflection draft. Continue recording meaningful experience without fabricating prompts or completed verification.

Tool and role

OpenAI Codex desktop agent, GPT-6 (session-provided model identity; exact service variant not independently recorded). Used for reading the Lab 3 PDF, explaining scope in Thai, inspecting the Lab 2 architecture, planning Issues, drafting the contract, implementing and testing features, addressing actual peer findings and preparing verification evidence. Independent approval belongs to the reviewer; see reviewer.md.

The handout is source material distinct from the user's request. User chose to begin the six-Issue plan and explicitly emphasized polished UI consistent with the assignment. The agent isolated work from existing uncommitted Lab 2 report edits and based the new contract on completed remote main.

Selected real prompt log

No.	User request (original Thai)	Use / result so far
1	lab 3 มาแล้วอธิบาย แล้วก็วางแผนที	Read 18-page handout and inspected mockups; explained scope/rules/deliverables and compared with existing Requester model/header context.
2	แล้วควรมีกี่ Issue	Proposed a dependency-aware 10-Issue decomposition; treated count as a proposal, not a handout requirement.
3	สามารถลดได้เหมือน เพราะต้องมารอเพื่อน Approve อีก	Consolidated to six Issues including release, with feature tests inside each and retained peer review.
4	ตอนนี้สามารถเริ่มเลย ได้ไหม	Began the contract work item, checked GitHub/main, created isolated branch/worktree and drafted seven linked planning/evidence documents.
5	ขอ UI สวยๆ และให้ ตรงใจทีนะ	Strengthened UI contract with concrete dimensions/hierarchy, queue table/mobile cards, separate private/public composers, narrow Admin UI and visual checklist.
6	แก้ไขแล้วผมต้อง รีวิวของเพื่อนควร แยกแชทไหม	Addressed Datakung's 2026-09-12 board/document mismatch review: return #26 to Backlog, correct #25 workflow and review records, preserve the separate local authentication draft, and prepare the correction for re-review. Recommended a separate conversation for reviewing the partner's repository.
7	เพื่อนส่งกลับมาแล้ว	Read the actual peer findings, fixed dirty navigation loss and ambiguous browser assertions, and added regression coverage.

No.	User request (original Thai)	Use / result so far
8	ใส่ให้ผมเลยได้ไหม	Drafted the Reflection below using recorded project events, explicitly retaining student review before submission.
9	ทำ issue ต่อเลย	Continued #29 with integrated checks, responsive/error-state evidence, real API failure/rollback coverage and a nine-part submission draft.

Verification and limitations

Issue #29 update (2026-09-25): Codex added four cross-role browser journeys and six real HTTP/database failure cases, retained the original regressions, and captured 109 images after all 17 browser journeys passed. Keyboard verification exposed a confirmation focus-cycle defect; it was corrected and rechecked in a real browser. Final full Vitest verification passed 389 cases across 36 files on a fresh isolated database. Earlier selector, test-stub and environment failures are recorded in system-verification.md. These are agent verification results, not the student's personal test execution or peer approval.

Selected implementation prompt: “ทำ 3 ต่อเลย”, followed by “ทำต่อเลย” after interruption. Codex implemented the Issue #27 queue/operations/conversation and Requester indication, then used real PostgreSQL/API/UI/browser tests to verify them. Testing caught a PostgreSQL advisory-lock result decoding defect; it was corrected to execute the lock without decoding its void result. Two browser test selectors were refined when the new UI added owner options and nested select labels. Original tests were retained and the failures are recorded in tests.md. The agent's observations are not the student's personal reflection.

Compare the four contract documents and test mapping before handoff. Planned tests and screenshots remain Planned. Record actual checks in reviewer.md/tests.md after execution. Technical security decisions reference primary Node/OWASP sources in specification.md. A contract self-check is not an independent peer review.

My Reflection

Peer-fix update (2026-09-21): the user said “เพื่อนส่งแก้มแล้ว”. Codex read Datakung's two inline findings on PR #34, reproduced dirty navigation loss with five failing App-level regressions, implemented the navigation guard, and scoped browser success assertions to their actual text. The correction preserves mandatory authentication redirects. Results are recorded separately from the original implementation and the reviewer's independent run; no first-person student reflection or peer approval is inferred.

Issue #28 continuation (2026-09-20): the user asked “จัดการต่อเลย”. Codex continued the administrator API/UI on an isolated branch based on the approved PR #33 merge, wrote concurrency and UI/browser tests, and checked real responsive screenshots. The first browser run identified missing opener focus after dismissing the reset dialog; the implementation was corrected rather than weakening the assertion. Docker startup was recovered by preserving stale socket-only runtime directories; no factory reset or development-data migration was performed. Actual execution results belong in tests.md, not a claimed student reflection or peer review.

Implementation update: after actual contract approval/merge, the user requested “เริ่มทำต่อเลย”. Codex implemented the #26 schema/session/authentication/UI increment, migrated old tests to session identity, ran real PostgreSQL migration/regression tests and browser tests, and inspected selected screenshots. Initial failing tests and the interrupted browser run are retained in tests.md rather than presented as passes. The user's later “ถึงไหนแล้ว” prompted a factual progress report. This work does not constitute peer approval or the student's own reflection.

ร่าง Reflection สำหรับ Answer Part 4

ร่างโดย Codex ตามคำขอของผู้ใช้ “ใส่ให้ผมเลยได้ไหม” เมื่อ 2026-09-25 โดยอิงจากเหตุการณ์ที่บันทึกไว้ในโครงการ ผู้ใช้ยังต้องอ่านและปรับข้อความให้ตรงกับประสบการณ์และความเข้าใจของตนก่อนส่ง ร่างนี้ไม่ใช่หลักฐานว่าผู้ใช้ได้ตรวจโค้ดหรือทดสอบด้วยตนเองแล้ว

การทำ Lab 3 แสดงให้เห็นว่าการพัฒนาระบบไม่ได้จบแค่หน้าเว็บแสดงผลได้ แต่ต้องมีข้อกำหนด สิทธิ์ของผู้ใช้ และหลักฐานการทดสอบที่สอดคล้องกัน เช่น Requester ควรเข้าถึงเฉพาะงานของตนเองและขอความช่วยเหลือ ส่วน IT Staff และ Administrator มีหน้าที่และสิทธิ์ต่างกัน การขออนุมัติในหน้าเว็บอย่างเดียวจึงไม่เพียงพอ ต้องตรวจสอบสิทธิ์ที่ API ด้วย

AI ช่วยอ่านและสรุปโจทย์ วางแผน Issues ร่าง specification และช่วยพัฒนาโค้ด ชดทดสอบ และเอกสารตามขอบเขตของแต่ละงาน การจัดงานเป็น 6 Issues ทำให้รวมการพัฒนาการทดสอบของแต่ละส่วนไว้ด้วยกัน และยังคงให้เพื่อนรีวิวก่อนรวมโค้ด อย่างไรก็ตาม โค้ดและเอกสารที่ AI สร้างยังต้องตรวจเทียบกับโจทย์และผลการทำงานจริง ไม่ควรถือว่าถูกต้องเพียงเพราะ AI รายงานว่าทำเสร็จ

ตัวอย่างที่ชัดเจนคือการรีวิว PR #34 พบว่าการออกจากหน้าจัดการผู้ใช้ขณะมีข้อมูลที่ยังไม่ได้บันทึกอาจทำให้ข้อมูลในฟอร์มหาย จึงมีการเพิ่มการยืนยันก่อนออกจากหน้าผ่านเมนูและปุ่ม Back/Forward พร้อมเพิ่ม regression tests อีกประเด็นคือ browser test ตรวจสอบสถานะกว้างเกินไป จึงแก้ไขตรวจสอบความสำเร็จของการทำงานนั้นโดยตรง เหตุการณ์นี้แสดงให้เห็นว่าการรีวิวช่วยพบทั้งปัญหาของระบบและจุดอ่อนของชุดทดสอบได้

ประเด็นที่ควรนำไปใช้ต่อไปคือการเริ่มจากข้อกำหนดที่ตรวจสอบได้ ทดสอบทั้งกรณีสำเร็จและกรณีผิดพลาด และบันทึกผลตามที่เกิดขึ้นจริง โดยแยกงานที่ทำแล้ว งานที่ผ่านการทดสอบ และงานที่เพื่อนอนุมัติออกจากกัน ผู้ส่งงานยังต้องอธิบายเหตุผลของการออกแบบ ตรวจสอบความถูกต้องของรายงาน และรับผิดชอบผลงานที่ส่ง แม้จะมี AI ช่วยเขียนโค้ดและเอกสารก็ตาม

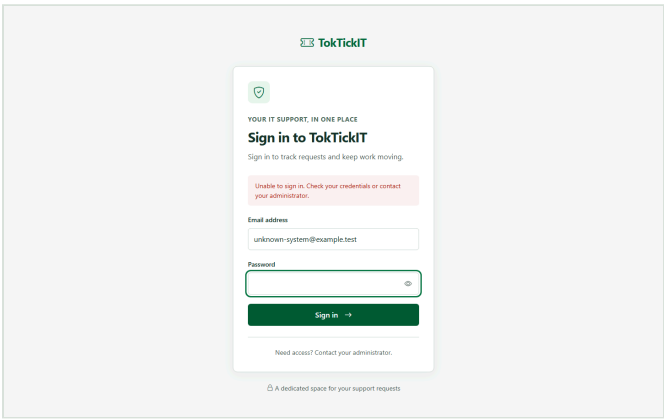
Answer Part 5

Authentication

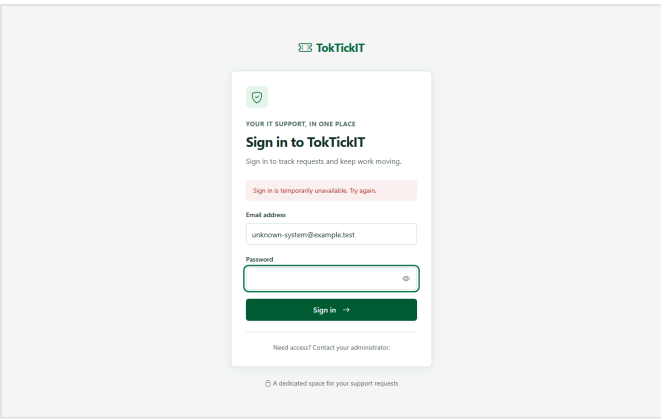
Real browser journeys cover login, mandatory password change and logout. Real API suites cover inactive users, session invalidation, role restrictions and direct access after logout. Component tests cover busy/error feedback. See the actual test mapping in Part 3; a screenshot alone does not prove authorization.

Login, invalid credentials and safe failure

Validation and failure feedback preserve a clear recovery path.



Desktop - invalid credentials
[Full-size evidence](#)

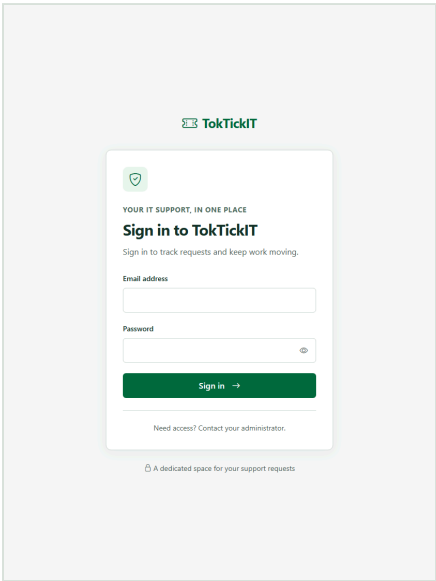


Desktop - simulated unavailable response
[Full-size evidence](#)

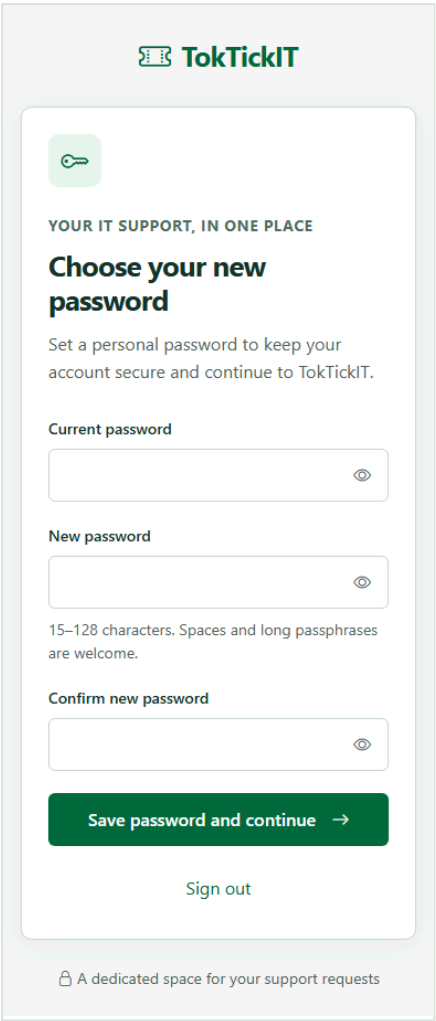
Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Names containing simulated use controlled browser responses.

Authentication across smaller screens

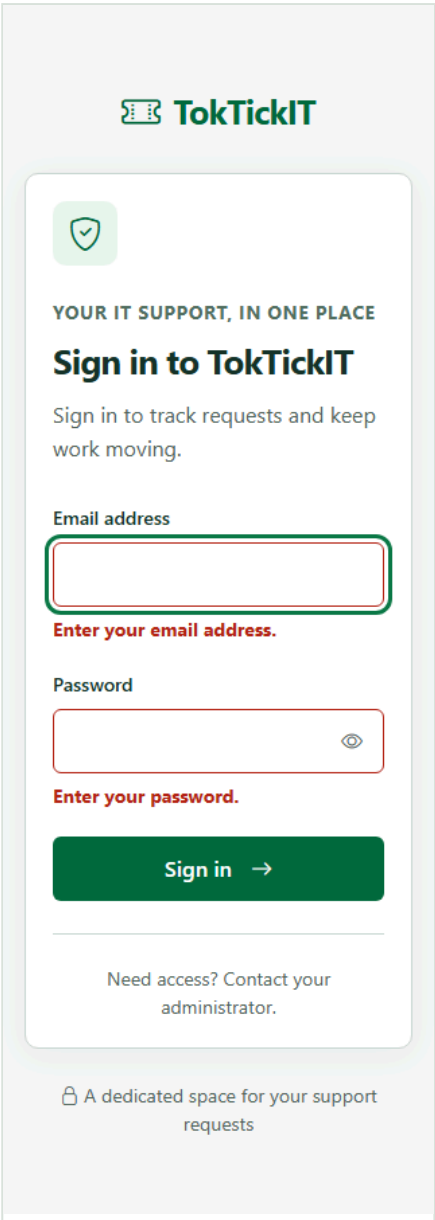
The complete image index also includes ready, busy, invalid and validation states at all four widths.



Tablet - ready
[Full-size evidence](#)



Mobile - mandatory password change
[Full-size evidence](#)



320px - validation
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Answer Part 6

Queue and ticket lookup

The queue provides search, filtering, sort, ownership and pagination. API assertions verify query semantics; browser journeys verify interactions and responsive layouts. Controlled responses explicitly supply empty/failure presentation states.

Staff queue - desktop

TokTickIT

Ticket Queue

Alex Morgan

IT Staff

Password

Logout

SUPPORT WORKSPACE

Ticket Queue

Find and prioritize support requests.

17 matching tickets

Search tickets

Ticket number, summary or description

Search

Status

All statuses

IT Priority

All priorities

Category

All categories

Owner

All owners

Sort by

Last updated

Order

Descending

Tickets per page

10

Apply filters

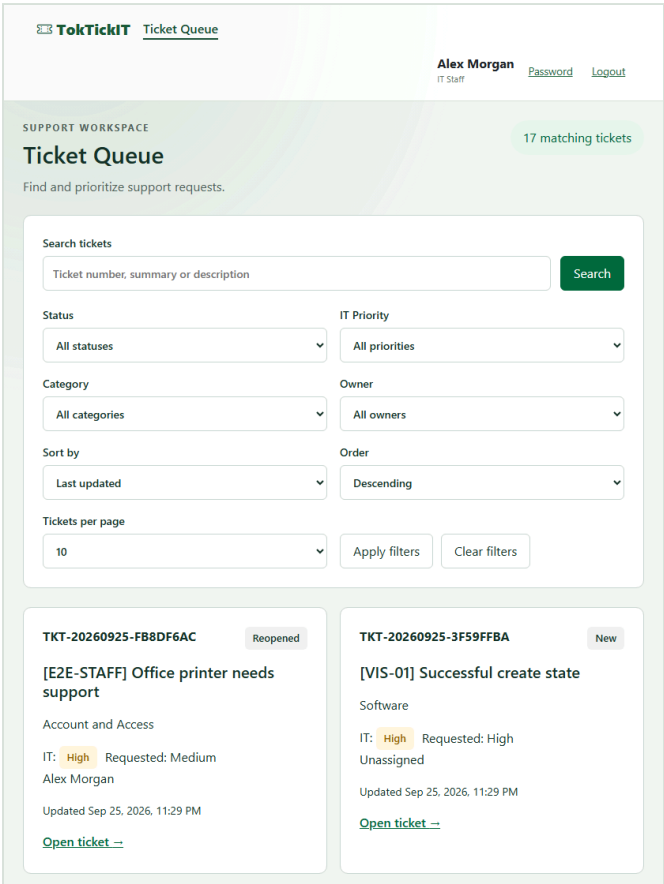
Clear filters

Ticket	Category	Priority	Status	Owner	Updated
TKT-20260925-FB8DF6AC [E2E-STAFF] Office printer needs support	Account and Access	High Requested: Medium	Reopened	Alex Morgan	Sep 25, 2026, 11:29 PM
TKT-20260925-3F59FFBA [VIS-01] Successful create state	Software	High Requested: High	New	Unassigned	Sep 25, 2026, 11:29 PM
TKT-20260925-5A58BAC4 [VIS-01] Attachment lifecycle evidence	Software	High Requested: High	New	Unassigned	Sep 25, 2026, 11:29 PM
TKT-20260925-11462170 [RESP-mobile] Long requester-visible summary Long requester-visible summary Long requester-visible summary	Software	High Requested: High	New	Unassigned	Sep 25, 2026, 11:29 PM

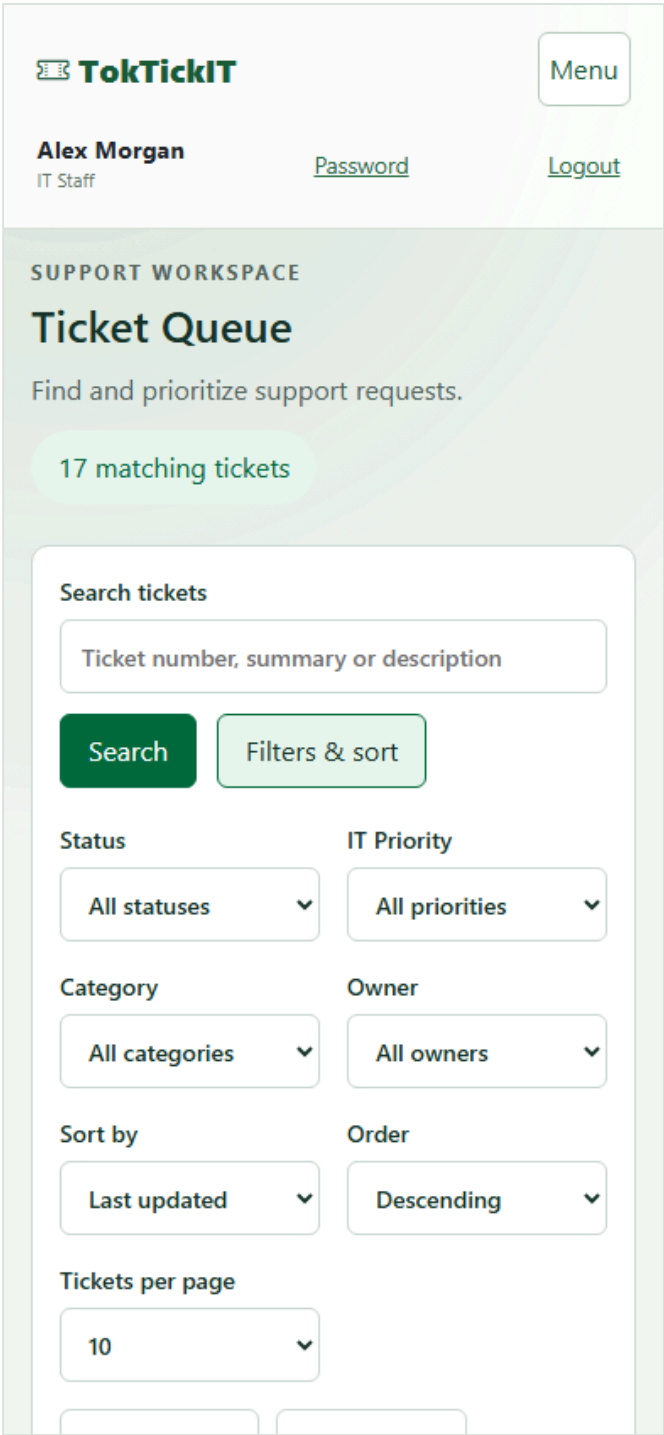
1440px - queue and filters
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Queue - tablet and mobile



834px - queue
Top excerpt of full-page capture
[Full-size evidence](#)

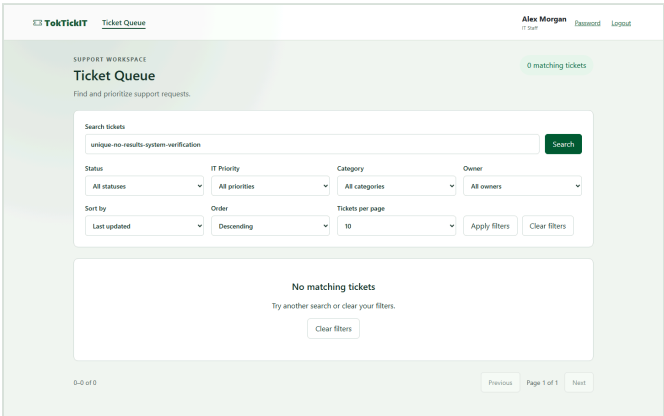


390px - queue
Top excerpt of full-page capture
[Full-size evidence](#)

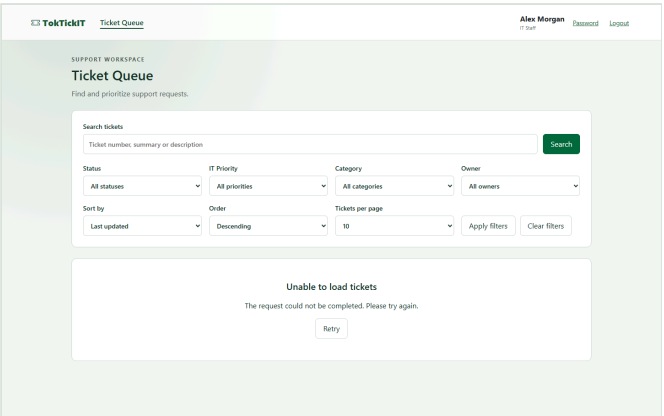
Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Queue feedback

The full index additionally includes the labelled simulated empty state and detail not-found.



No matching results
[Full-size evidence](#)



Simulated failure and recovery
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Names containing simulated use controlled browser responses.

Answer Part 7

Ticket workflow, conversations and permissions

Staff browser/API coverage exercises claim, assignment, priority and state changes, public comments, private notes, downloads, closing/reopening and version conflict. Requester ownership, private-data exclusion, terminal writes and narrow Admin permissions are checked through direct API requests. Migration fixtures preserve synthetic attachment metadata and file hashes.

Ticket operations and public conversation

The screenshot displays the TokTickIT Ticket Queue interface. At the top, the header includes the TokTickIT logo, 'Ticket Queue', and user information for Alex Morgan (IT Staff) with links for Password and Logout. A 'Back to Queue' button is located at the top left of the ticket details area. The ticket ID is TKT-20260925-679E5401, and it is marked as 'New'. The ticket title is '[VIS-desktop] Printer support with a long descriptive summary for responsive verification', and it was updated on Sep 25, 2026, at 11:30 PM.

The ticket details are organized into three main sections:

- Ticket information:** This section contains fields for Requester (Jennifer Anderson, e2e.jennifer@example.test), Created (Sep 25, 2026, 11:30 PM), Category (Software), Related System (Customer Portal), Requested Priority (High), and IT Priority (High).
- Description:** This section contains a text box with the description: 'Deterministic requester journey evidence for the Lab 2 quality gate.'
- Attachments:** This section contains a list of attachments, including 'synthetic-printer-diagnostic.png', with a 'Download' button next to it.

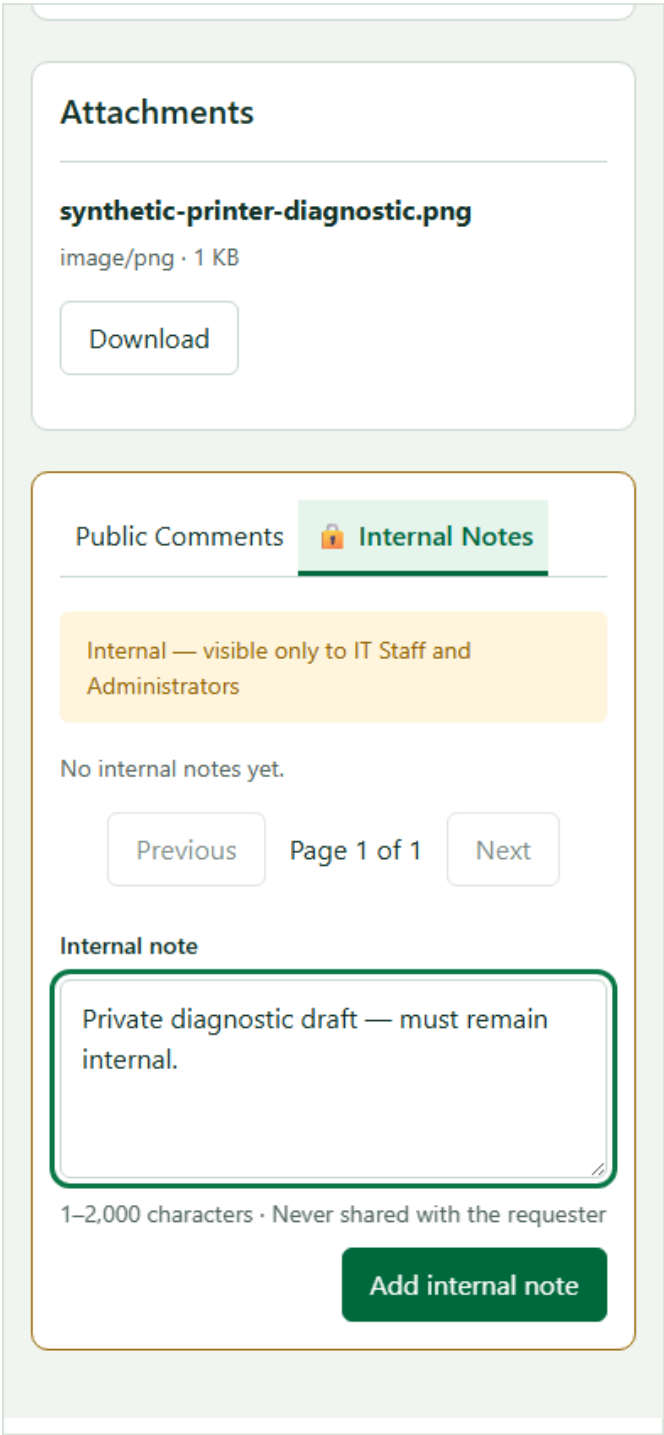
The 'Manage ticket' section on the right side of the interface includes the following controls:

- Owner:** Currently 'Unassigned', with a 'Claim ticket' button.
- Assign to:** A dropdown menu currently set to 'Unassigned', with an 'Assign / Reassign' button.
- IT Priority:** A dropdown menu currently set to 'High', with a 'Save priority' button.
- Next status:** A dropdown menu currently set to 'Choose next status'.

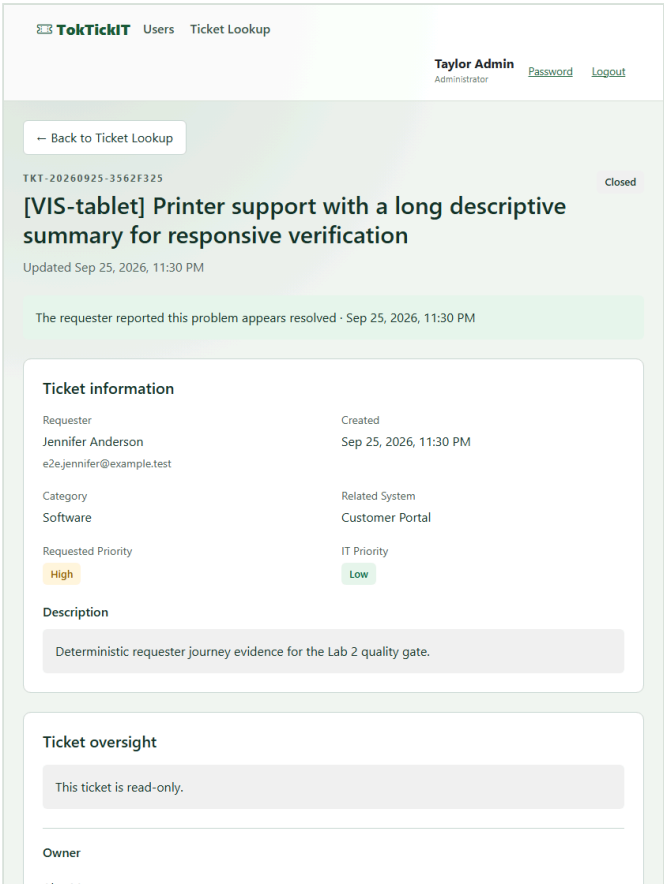
Staff - public conversation
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Private notes and restricted administration



Mobile - private conversation
Bottom excerpt of full-page capture
[Full-size evidence](#)



Tablet - Admin restricted operations
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Requester public conversation and resolution indication

The linked full-page captures include the attachment controls above these excerpts.

Download

Remove

Is the problem resolved?

IT Staff will review this and formally resolve or close your ticket.

Problem appears resolved

Public Comments

Visible to the requester

Alex Morgan

It Staff

Sep 25, 2026, 11:30 PM

We are checking the printer connection.

Previous

Page 1 of 1

Next

Public comment

1–2,000 characters · Shared with everyone on this ticket

Post public comment

Requester - public conversation
Bottom excerpt of full-page capture
[Full-size evidence](#)

Download

Remove

You reported this problem appears resolved · Sep 25, 2026, 11:30 PM. IT Staff will review it.

Public Comments

Visible to the requester

Alex Morgan

It Staff

Sep 25, 2026, 11:30 PM

We are checking the printer connection.

Previous

Page 1 of 1

Next

Public comment

1–2,000 characters · Shared with everyone on this ticket

Post public comment

Requester - resolution indication
Bottom excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Concurrent edit recovery

The current server state must be reloaded and reviewed; the interface does not silently overwrite it.

TokTickIT

Ticket Queue

Alex Morgan
IT Staff

[Password](#)

[Logout](#)

← Back to Queue

TKT-20260925-679E5401

New

[VIS-desktop] Printer support with a long descriptive summary for responsive verification

Updated Sep 25, 2026, 11:30 PM

This ticket changed or the action is no longer available.
Your attempted selections are still shown. Reload the latest details before trying again.

Reload latest details

Ticket information

Requester

Jennifer Anderson

e2e.jennifer@example.test

Created

Sep 25, 2026, 11:30 PM

Category

Software

Related System

Customer Portal

Requested Priority

High

IT Priority

High

Description

Deterministic requester journey evidence for the Lab 2 quality gate.

Manage ticket

Owner

Unassigned

Claim ticket

Assign to

Unassigned

Assign / Reassign

IT Priority

Medium

Requested priority stays unchanged.

Real version conflict
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

TOKTICKIT / LAB 03 / REVIEW DRAFT - final-main acceptance pending

41 / 50

Answer Part 8

Administrator user management

Account lifecycle coverage includes create/edit/reset, exactly one role, activation, required password change and non-admin denial. Real API tests cover duplicates, stale edits, self-deactivation, concurrent last-admin removal and active-owner protection. Browser regressions retain dirty form data when navigation is cancelled.

User directory - desktop

TokTickIT

Users

Ticket Lookup

Taylor Admin

Administrator

Password

Logout

ADMINISTRATION

Users

+ Create user

A well-organized team starts with the right access.

Search users

Search name or email

Role filter

All roles

Search

18 accounts in your workspace

NAME	EMAIL	ROLE	STATUS	
A Alex Morgan	e2e.staff@example.test	It Staff	Active	Edit
A Alex Rivera	alex.staff@example.test	It Staff	Active Password change required	Edit
A Archived Requester	archived.requester@example.com	Requester	Inactive Password change required	Edit
A Archived Staff	archived.staff@example.test	It Staff	Inactive Password change required	Edit
I Initial Password Evidence	e2e.visual-initial@example.test	It Staff	Active Password change required	Edit
I Initial Staff E2E	e2e.initial@example.test	It Staff	Active	Edit

Directory with role, activity and edit actions
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

User editor and initial-password reset

TokTickIT

Users

Ticket Lookup

Taylor Admin

Administrator

Password

Logout

← Back to Users

MANAGE ACCOUNT

Edit user

Keep account details and access up to date.

Name

Taylor Admin

Email

e2e.admin@example.test

Role

Administrator

☒ Active account

Your own account must stay active.

Cancel

Save changes

Password access

Set a new initial password if this user needs help signing in.

Set new initial password

Tablet - editor and account safety
[Full-size evidence](#)

TokTickIT

Menu

Taylor Admin

Administrator

Password

Logout

← Back to Users

MANAGE ACCOUNT

Edit user

ACCOUNT SECURITY

Set a new initial password

All existing sessions for **Taylor Admin** will end. They must change this password when they next sign in.

This is your account. You will return to sign in after saving.

Initial password

Show

Use 15–128 characters. Share this initial password with the user securely.

Confirm initial password

Cancel

Set initial password

Set new initial password

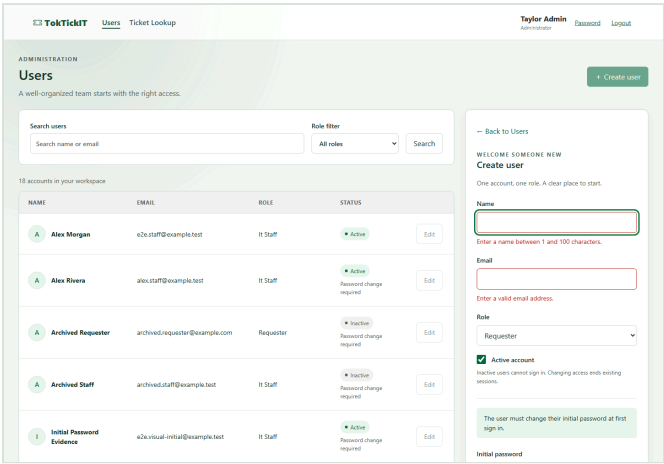
Mobile - reset dialog
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

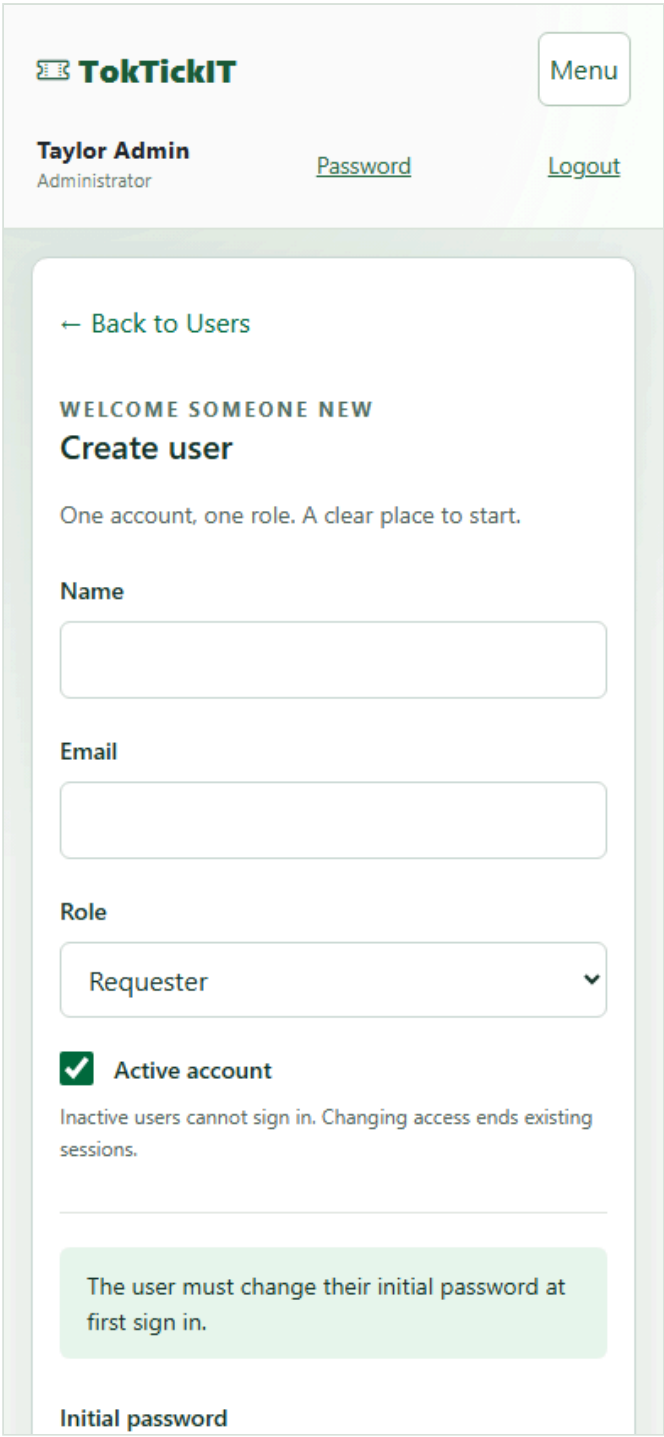
TOKTICKIT / LAB 03 / REVIEW DRAFT - final-main acceptance pending

43 / 50

Account creation validation



Desktop - create validation
Top excerpt of full-page capture
[Full-size evidence](#)



Mobile - create form
Top excerpt of full-page capture
[Full-size evidence](#)

Staging capture 2026-09-25T16:31:23.371Z; source 08d37115e4f8. Synthetic fixture data. Real browser and API state.

Answer Part 9

UI specification, responsive evidence and final inspection

Agent image inspection and automated geometry/keyboard checks are recorded in Part 3. The final HUMAN checklist, native browser zoom and final-main captures remain pending; unchecked boxes below are deliberate.

Selected figures in Parts 5-8 show desktop, tablet, mobile and narrow evidence. [Full image index](#) and [SHA-256 manifest](#) link all 109 images. Every digest was checked again when generating this draft. Text and links remain selectable. Simulated responses are labelled; all fixture identities are synthetic.

Rendered source: [docs/lab-03/ui-spec.md](#) - complete document; dated historical entries retained.

Lab 3 Zen Green UI Specification

Status (2026-09-26): Implementation, integrated evidence and accessibility corrections are peer-approved and merged through PR #35. Issue #30 prepares the final release. [System verification](#) records actual image inspection and distinguishes it from the final human checklist, which remains pending.

User direction (2026-09-08): polished, attractive UI that follows the assignment. Reuse the Lab 2 design system; make the first staff/admin increment feel like one coherent product.

1. Visual direction and reusable components

Use a quiet off-white canvas, white cards, restrained borders, deep-green navigation, generous spacing and strong typography. Prioritize a clear page title, task context and one dominant action per panel. Avoid excessive shadows, gradients, decorative charts, oversized marketing copy and crowded spreadsheets. Preserve the existing TokTickIT wordmark; no new logo or imagery is needed.

Inherited tokens from [Lab 2 UI specification](#): primary #006B3C, hover #005A33, secondary/focus #0B7A46, pale green #EAF6EF, page #F5F7F6, surface #FFFFFF, text #17352A, muted #52665E, border #CCD8D2, readonly #F0F3F1, error #B42318 / #FEF3F2, warning #9A6700 / #FFF7E0. No hard-coded alternative theme colors in feature screens. Semantic badges combine these existing tokens with explicit labels/icons.

Element	Contract
Content width	Queue/admin max 1200px; detail max 1120px; login/password card max 440px. Center content.
Header	64px desktop; brand, role navigation, current user/role, Logout. Mobile allows two clean rows/menu without clipping.
Page spacing	32px desktop, 24px tablet, 16px mobile; 24px between sections and 16px inside related groups.
Type	Existing Inter/Segoe UI/system stack; body 16px/1.5, labels/helper text >=14px; page titles 30px desktop/26px mobile.
Surfaces	Cards 10px radius, 1px neutral border; use existing subtle shadow sparingly. Buttons/inputs 6px radius.
Controls	>=44px height and 44x44 touch targets; visible labels; no unlabeled icon-only primary action.
Tables	Calm header, 14-16px text, >=64px ticket rows, clear hover/focus; row links remain explicit.
Focus/error	2-3px visible token-based focus ring; inline linked field errors; summary/banner announces submit failures.

Extract/reuse ApplicationShell, PageHeader, FormField, Button, StatusBadge, PriorityBadge, RoleBadge, StatePanel, ConfirmationDialog, Pagination and AttachmentList from established styles. Share ticket information blocks between Requester and staff detail. Components accept permitted actions/data; backend authorization remains authoritative. Avoid three

duplicated detail forms with divergent validation.

2. Routes and navigation

Route	Screen / permission
/login	Public login card
/change-password	Any authenticated role; only application route for initial-password user
/tickets, /tickets/new, /tickets/:ticketId	Requester own workflows
/staff/tickets, /staff/tickets/:ticketId	IT Staff queue/detail; Administrator secondary Ticket Lookup with narrow rights
/admin/users	Administrator user management

Landing pages: Requester My Tickets; IT Staff Ticket Queue; Admin Users. Admin secondary navigation says Ticket Lookup, not My Queue. Current-user bootstrapping shows a neutral busy shell before protected content; never flash another role's controls. Preserve only a validated internal permitted intended route after login; otherwise use the role landing page. No open redirects.

Legacy /select-requester redirects to login. Remove Development Requester selector/notice, Change Requester, X-Requester-Id headers and persisted identity state. Logout first revokes server access, then clears all protected caches/drafts/creation keys and returns to login. On failed logout, show retry and do not claim successful revocation. On 401 from any protected request, clear protected data and return to login with concise session-expired feedback. 403 PASSWORD_CHANGE_REQUIRED navigates to password change; other 403 shows forbidden without stale content.

3. Login and Change Password

Login: centered white card with brand, "Sign in to TokTickIT", brief helper, Email, Password with accessible show/hide button, and full-width Sign In. No social-login, registration or forgotten-password email links. Use autocomplete username/current-password; allow paste. Empty/invalid email fields get inline errors. Busy button reads "Signing in..." and prevents double submission. Generic credential failure does not identify inactive versus unknown users. Rate-limit feedback shows wait/retry guidance from Retry-After. Network failure retains email; clear password on success/navigation and never persist it.

Change Password: same visual card, heading "Choose your new password", explanation of initial-password requirement, Current Password, New Password, Confirm Password, always-visible 15-128 character passphrase guidance and primary "Save password and continue". New fields use autocomplete new-password. Show mismatch/length/current-password validation where it occurs. Initial-password users have Logout available but no application navigation or skip action. Successful change opens the role landing page. Ordinary voluntary password change uses the same form and may offer a Back action for full sessions.

4. Requester continuity

Preserve Create Ticket/My Tickets/Attachment usability and field validation from Lab 2. Current name comes from the session. New IT Priority is displayed as a read-only badge equal to Requested Priority initially. Requester detail contains grouped ticket metadata, description, Attachments and a Public Comments section; no Internal Notes tab, badge, count or empty placeholder.

In allowed states, show a secondary "Problem appears resolved" action with a confirmation explaining "IT Staff will review this and formally resolve or close your ticket." On success display "You reported this problem appears resolved" with server time; keep the actual status badge unchanged. Disable the repeat action with explanatory text. CLOSED/CANCELLED conversations show readable history and "This ticket is read-only"; existing Requester attachment actions remain available under inherited ownership rules.

5. IT Staff Ticket Queue

Page header: "Ticket Queue", short context "Find and prioritize support requests", and count of matching results. No create-ticket action for staff. A search field spans useful width with explicit label and clear action; filter toolbar contains Status, IT Priority, Category and Owner (All, Unassigned, Assigned to me, eligible named owner), plus Sort and Clear Filters. Queries apply on Search/Apply or Enter, not every keystroke; changes reset page to 1. For Admin lookup omit owner-selection lookup and present All/Unassigned/Assigned to me only; API UUID filtering remains available to authorized queries.

Desktop table uses six columns to avoid a mega-grid:

Column	Display
Ticket	Green linked Ticket Number and Summary below; summary wraps to two lines; accessible full text in the detail link
Category	Plain readable label
Priority	IT Priority badge prominent; secondary labelled "Requested: High" (or actual value)
Status	Text/icon status badge with enough width for Waiting for Requester
Owner	Name or neutral "Unassigned"; historical inactive owner explicitly labelled
Updated	Localized date/time with full timestamp available; no ambiguous relative-only time

Created date and Related System belong in detail; sorting by created date remains in the Sort control. The result range and page-size control sit below the table with Previous/Next and page numbers. Stable row heights, aligned cells and restrained badge colors matter more than maximum density. Do not make the whole row an inaccessible click target.

At tablet widths stack the toolbar and use ticket cards if six columns would squeeze labels. Below 768px always use cards: number/status in first row, summary, category, requested/IT priority, owner/update, explicit "Open ticket" link. Show filters in a collapsible inline panel with aria-expanded; no horizontal page scrolling.

States: loading skeleton matching result layout; empty queue "No tickets yet"; filtered no-results with Clear Filters; failure panel with Retry; forbidden with a permitted-home link. Failed queries never silently display old results under new filter labels. On a background refresh failure, retained results must be labelled as previous results and kept bound to their original query.

6. IT Staff Ticket Detail

Top: breadcrumb Back to Queue, Ticket Number and summary, status badge and updated timestamp. Desktop grid uses approximately 2fr content / 1fr operational card; narrow screens stack ticket content, operational controls, attachments and conversation in that order. No sticky panel may obscure focus or content.

Content card: requester, created date, category, related system, requested priority, description. Historical data are read-only text on subtle readonly surfaces, not disabled low-contrast inputs. Long descriptions/filenames wrap safely.

Operational card: owner, "Claim ticket" if unassigned, owner picker + confirmed Assign/Reassign, IT Priority selector + Save, permitted-next-status selector + Update. Keep each operation's busy/success/error feedback local. Selecting values does not immediately mutate the server. Show only valid next statuses, but also explain why an action is unavailable (for example "Assign an active owner before starting work"). Confirm resolve/close/reopen/cancel with the ticket number and exact target state. Reassignment shows old/new owner. Cancelling a dialog leaves values/data unchanged.

Admin detail uses the same read-only content and conversation/attachment views, with only IT Priority editable. Never show Claim, owner editing, status editing or a conversation composer for Admin. This visibly implements the narrow authorization matrix.

Conversation uses separate "Public Comments" and "Internal Notes" tabs for Staff/Admin. A Public composer carries the label "Visible to the requester"; Internal Notes shows a lock icon, amber-tinted header and "Internal - visible only to IT Staff and Administrators". Separate draft state per tab; switching never copies private text to the public draft. Post buttons read "Post public comment" and "Add internal note". Display author, role and timestamp on each entry. Render plain text, never raw HTML. Keep tabs keyboard operable; show the active tab in text/underline, not just color.

For uncertain post failures retain the relevant draft and reload conversation before offering Retry; no automatic append retry. For version conflict preserve the attempted selection separately, show "This ticket changed. Reload the latest details before trying again", and require a fresh deliberate submit after reload. Never silently overwrite a colleague's work.

Attachments reuse the existing list: safe filename/type/size, active Download, Removed/Unavailable labels, no preview. Staff/Admin have no upload/remove controls. Requester indication appears as a pale-green callout distinct from the formal status.

7. Minimal Administrator User Management

Page header: "Users", brief helper, primary "Create user". Search by name/email and one optional Role filter; no dashboard cards, bulk actions, export, delete, departments or mandatory pagination.

Desktop: table columns Name, Email, Role, Status, Edit; editing/creation opens a right-hand panel around 400px wide with a clearly labelled close/cancel action. At tablet/mobile use a full-width form view and Back to Users, avoiding two narrow columns. Table becomes cards on mobile, with a visible Edit button for every item.

Create form: Name, Email, single Role select, Active switch with textual Active/Inactive state, Initial Password with show/hide and confirmation. UI confirmation is compared before sending the API's initialPassword field. Save User/Cancel at the bottom. Explain initial password must be communicated manually and changed on first login. No "send password reset email" checkbox from the sample image.

Edit form: same basic fields except password; separate "Set new initial password" action opens a small confirmation dialog with initial/confirm fields. Explain it signs out existing sessions and forces a password change. An Admin's own Active switch is locked active with helper text; backend still enforces it. Last-admin and active-ticket-owner failures show the safe reason next to the attempted role/activation control and preserve entered basic data. No deletion button.

After create/edit refresh the list from server data and announce success. Reset clears password inputs immediately after success and shows no password in list/toast/log. If own role/reset revokes the session, return to login with an accurate explanation. Conflicts require reload/review; no silent overwrites. Dirty non-password form closes require discard confirmation. Password drafts clear on cancel/unmount.

8. Required modes, feedback and accessibility

Main modes are login/change-password, list, view, create and edit. Loading/validation/conflict are feedback within these modes, not invented formal business states. Every implemented screen must demonstrate meaningful busy, success, safe failure and forbidden behavior; lists additionally demonstrate empty/no-results; details demonstrate not-found; versioned forms demonstrate conflict.

Use semantic headings and landmarks, labelled inputs, aria-describedby errors, aria-invalid and live status messages. On invalid submit focus the first invalid field. Dialogs support Escape where cancellation is permitted, focus trapping, labelled title and focus restoration. Menus expose expanded state. Statuses/roles/priorities contain readable text; icons complement it. Keep normal text contrast consistent with inherited WCAG AA design targets. Check browser zoom and long content manually; automated DOM assertions do not prove visual quality.

9. Responsive and visual evidence

Breakpoints: desktop >=992px; tablet 768-991px; mobile <768px. Verify 1440x900, 834x1112, 390x844 plus a narrow 320px overflow check. Major screenshot groups under artifacts/lab-03/screenshots/:

Folder	Required scenes at desktop/tablet/mobile
authentication/	login-ready, login-invalid, change-password, authenticated role navigation
staff-queue/	realistic results and responsive filters/pagination; supplementary empty/no-results/failure
staff-ticket-detail/	operational controls + Public Comments, clearly distinct Internal Notes, conflict/validation/terminal states, Admin restricted view
user-management/	user list, create/edit, initial-password dialog, safety validation
requester/	owned detail with public conversation/resolution indication and attachment continuity

Use consistent names <viewport>-<scene>.png; routine test captures stay in ignored test-results, curated captures use an explicit evidence command. Screenshot fixtures are synthetic, show no passwords/tokens and have enough rows/text to test realistic density.

Integrated capture uses `npm run test:e2e:capture:lab3` and groups the required scenes under `artifacts/lab-03/screenshots/system/{system-states,staff-workflow,user-management}`. Its manifest is the authoritative filename index. `system-states` includes authentication, Requester, conflict/terminal and restricted Admin scenes; inherited feature captures

retain their original names. Explicitly simulated busy/failure/empty scenes are labelled in filenames. The integrated browser check found a confirmation keyboard-cycle defect; shared confirmation and reset dialogs now explicitly wrap focus and preserve Escape/opener behavior. The final human checklist below remains distinct from agent inspection recorded in system-verification.md.

Final human visual checklist (all unchecked until actual inspection):

- [] Same tokens, typography, spacing, radii and primary-action hierarchy across all roles.
- [] Queue readable without an oversized grid; mobile cards retain all important fields/actions.
- [] Internal/private composer unmistakable; no private draft appears in public composer.
- [] Read-only and editable fields, status/priority/role badges and inactive accounts are clear.
- [] Busy, success, validation, safe failure, forbidden, no-results, not-found and conflict are legible.
- [] No clipped labels, overlapping cards/dialogs, offscreen actions or horizontal page overflow.
- [] Keyboard focus/dialog restoration, linked errors, labels, text contrast and touch targets checked.
- [] No excluded reset-email/Service Actions/admin bulk features copied from illustrative screenshots.
- [] Screenshots correspond to the final reviewed commit; results recorded in tests.md.

Remaining release acceptance

Rendered source: docs/lab-03/release.md - complete document; dated historical entries retained.

Release integration and submission - Issue #30

Status: Started on 2026-09-26. This is the sixth planned work item, using `lab3-staging -> main`. Feature Issues #25-29 are complete. The application baseline is the peer-merged PR #35 commit `e685eec892d2b09fdeeeafcb8dc0c253ae6c4f31`. Release preparation changes documentation and the report builder only.

What is already verified

DataKung approved PR #35 head `3d251ce2ecd074bb18792f0b7aae85a0589645a`, independently passing 389 tests, 17 browser journeys and both builds, and matching all 109 image checksums. Approval: 2026-09-25 18:07:08 UTC; peer merge: 18:07:29 UTC. See [review history](#), [actual run and failure history](#), and [capture manifest](#).

These checks found no remaining blocker. They are not a promise that every possible bug is absent, and they are not final-main verification. Release documentation and PDF preparation do not change the reviewed application.

Review boundary and completion checklist

- [x] Features #25-29 independently reviewed and merged into staging.
- [x] Release work begins from the actual PR #35 merge, preserving the contract and earlier evidence.
- [] Release PR formally linked to #30, Project moved to PR Review, and live relationship/status verified.
- [] Peer reviews the release head and performs the staging-to-main merge.
- [] Record the actual main merge SHA and rerun all suites and both builds on that checkout.
- [] Capture final-main screenshots with truthful provenance; retain complete command outputs, including any failures and corrections.
- [] Student reads/adapts the Reflection and performs the human visual/native browser zoom checks in [ui-spec.md](#).
- [] Finish one PDF with Answer Part 1-9, working links, readable screenshots, rendered contract/review/test/AI/UI documents, final graph and completed Project evidence.
- [] Close #30 and move it to Done only after the above acceptance evidence is complete. If GitHub closes the linked Issue automatically on merge, reopen it until these post-merge checks are finished.

Do not self-approve or self-merge. Do not copy staging results under a final-main label. If a substantive defect appears, fix it through a reviewed correction instead of bypassing review to retain the six-PR estimate.

Reproducing the review PDF

The report is deliberately marked **REVIEW DRAFT** on every page. It renders the existing source documents, includes selected staging captures and links the full image index. Historical pending statements retain their original dates; the current status above and at the top of reviewer.md takes precedence. The student's Reflection remains an explicitly labelled AI draft.

After installing the root dependencies with `npm ci` and the Playwright Chromium browser with `npx playwright install chromium`:

```
node scripts/lab-03/build-review-report.cjs
```

Outputs are ignored local artifacts: `output/pdf/lab-3-review-draft.pdf` and `tmp/pdfs/lab-3-review-draft.html`. The builder reads only repository files, verifies every screenshot SHA-256, embeds local images, disables network requests during rendering and prints with Chromium. It requires an installed Thai font (Tahoma on Windows or Noto Sans Thai on Linux) for the original prompt log and Reflection. Inspect the rendered PDF, including Thai text, before sharing it.

The builder intentionally cannot label this preliminary report as final. After the actual merge, add the final-main execution logs and acceptance evidence, replace pending sections, and render/inspect the completed submission. Do not simply remove the draft footer.

Final-main runbook (pending actual merge)

Use a clean checkout of the actual peer-merged main and record `git rev-parse HEAD` and `git status --short` before testing. Install root, server and client dependencies as documented in [README](#), then generate Prisma. Use fresh, separately named test-only PostgreSQL databases, for example `lab3_release_unit_test` and `lab3_release_browser_test`, accepted by the existing test-database guard. Do not use development data or reuse a database left by an interrupted suite.

Run sequentially and preserve each command's complete output and exit code:

```
# Set TEST_DATABASE_URL to the fresh unit/API test database first.
npm run prisma:generate
npm test
# Change TEST_DATABASE_URL to the separate fresh browser test database.
$env:E2E_CLIENT_PORT = '3500'
$env:E2E_API_PORT = '5500'
npm run test:e2e:capture:lab3
npm run build:server
npm run build:client
git diff --check
```

The capture command runs the whole browser suite and copies images only after success. Its existing manifest note describes staging; after a final-main run, preserve the exact captured SHA, time and dirty-path fields and explicitly annotate that this capture was run on the verified main checkout. Do not change source to obtain a cleaner-looking provenance record. Capture output makes the working tree dirty only after the run; distinguish that generated evidence from application changes.

Store final logs, actual release review/merge facts and the final PDF as linked release evidence on Issue #30. Record final Project and Git history after acceptance. The post-merge evidence attachment does not require inventing another feature Issue. A source-code correction does require a new reviewed change.